

(6) 不间断供电: 采用不间断供电电源, 防止电压波动、电器干扰和断电等对计算机系统的不良影响。

(7) 电器噪声防护: 采取有效措施, 减少机房中电器噪声干扰, 保证计算机系统正常运行。

(8) 突然事件防护: 采取有效措施, 防止/减少供电中断、异常状态供电(指连续电压过载或低电压)、电压瞬变、噪声(电磁干扰)以及由于雷击等引起的设备突然失效事件的发生。

3. 计算机设备

计算机设备的安全保护包括设备的防盗和防毁以及确保设备的安全可用。

1) 设备的防盗和防毁

根据对设备安全的不同要求, 设备的防盗和防毁分为如下几种。

(1) 设备标记要求: 计算机系统的设备和部件应有明显的无法去除的标记, 以防更换和方便查找赃物。

(2) 计算中心防盗

① 计算中心应安装防盗报警装置, 防止从门窗进入的盗窃行为。

② 计算中心应利用光、电、无源红外等技术设置机房报警系统, 并由专人值守, 防止从门窗进入的盗窃行为。

③ 利用闭路电视系统对计算中心的各重要部位进行监视, 并有专人值守, 防止从门窗进入的盗窃行为。

(3) 机房外部设备防盗: 机房外部的设备, 应采取加固防护等措施, 必要时安排专人看管, 以防止盗窃和破坏。

2) 设备的安全可用。

根据对设备安全的不同要求, 设备的安全可用分为如下几种。

(1) 基本运行支持: 信息系统的所有设备应提供基本的运行支持, 并有必要的容错和故障恢复能力。

(2) 设备安全可用: 支持信息系统运行的所有设备, 包括计算机主机、外部设备、网络设备及其他辅助设备等均应安全可用。

(3) 设备不间断运行: 提供可靠的运行支持, 并通过容错和故障恢复等措施, 支持信息系统实现不间断运行。

4. 通信线路

根据对通信线路安全的要求, 通信线路安全防护分为如下几种。

(1) 确保线路畅通: 采取必要措施, 保证通信线路畅通。

(2) 发现线路截获: 采取必要措施, 发现线路截获事件并报警。

(3) 及时发现线路截获: 采取必要措施, 及时发现线路截获事件并报警。

(4) 防止线路截获: 采取必要措施, 防止线路截获事件发生。

17.3.2 技术控制

1. 检测监视系统

应建立门禁控制手段，任何进出机房的人员应经过门禁设施的监控和记录，应有防止绕过门禁设施的手段；门禁系统的电子记录应妥善保存以备查；进入机房的人员应佩戴相应证件；未经批准，禁止任何物理访问；未经批准，禁止任何人将移动计算机或相关设备带离机房。

机房所在地应有专设警卫，通道和入口处应设置视频监控点，24小时值班监视；所有来访人员的登记记录、门禁系统的电子记录以及监视录像记录应妥善保存以备查；禁止携带移动电话、电子记事本等具有移动互联功能的个人物品进入机房。

2. 人员进出机房和操作权限范围控制

应明确机房安全管理责任人，机房出入应由指定人员负责，未经允许的人员不准进入机房；获准进入机房的来访人员，其活动范围应受限制，并有接待人员陪同；机房钥匙由专人管理，未经批准，不准任何人私自复制机房钥匙或服务器开机钥匙；没有指定管理人员的明确准许，任何记录介质、文件材料及各种被保护品均不准带出机房，与工作无关的物品均不准带入机房；机房内严禁吸烟及带入火种和水源。

所有来访人员需经过正式批准，登记记录应妥善保存以备查；获准进入机房的人员，一般应禁止携带个人计算机等电子设备进入机房，其活动范围和操作行为应受到限制，并有机房接待人员负责和陪同。

17.3.3 环境与人身安全

环境与人身安全主要是防火、防漏水和水灾、防静电、防自然灾害以及防物理安全威胁等。

1. 防火

根据对机房安全保护的不同要求，机房防火分为如下几种。

(1) 机房和重要的记录介质存放间，其建筑材料的耐火等级，应符合 GBJ 45-1982 中规定的二级耐火等级；机房相关的其余基本工作房间和辅助房，其建筑材料的耐火等级应不低于 TJ 16-1974 中规定的二级防火等级。

(2) 设置火灾报警系统，由人来操作灭火设备，并对灭火设备的效率、毒性、用量和损害性有一定的要求。

(3) 设置火灾自动报警系统，包括火灾自动探测器、区域报警器、集中报警器和控制器等，能对火灾发生的部位以声、光或电的形式发出报警信号，并启动自动灭火设备，切断电源、关闭空调设备等。

(4) 设置火灾自动消防系统，能自动检测火情、自动报警，并自动切断电源和其他应急开关，自动启动固定安装好的灭火设备进行自动灭火。

(5) 机房布局应将脆弱区和危险区进行隔离,防止外部火灾进入机房,特别是重要设备地区,应安装防火门、机房装修使用阻燃材料等。

(6) 计算机机房应设火灾自动报警系统,主机房、基本工作间应设卤代烷灭火系统,并按有关规范的要求执行。报警系统与自动灭火系统应与空调、通风系统联锁。空调系统所采用的电加热器,应设置无风断电保护。

(7) 凡设置卤代烷固定灭火系统及火灾探测器的计算机机房,其吊顶的上、下及活动地板下,均应设置探测器和喷嘴。

(8) 吊顶上和活动地板下设置火灾自动探测器,通常有两种方式。一种方式是均匀布置,但密度要提高,每个探测器的保护面积为 $10\sim 15\text{m}^2$ 。另一种方式是在易燃物附近或有可能引起火灾的部位以及回风口等处设置探测器。

(9) 主机房宜采用感烟探测器。当没有固定灭火系统时,应采用感烟、感温两种探测器的组合。可以在主机柜、磁盘机和宽行打印机等重要设备附近安装探测器。在有空调设备的房间,应考虑在回风口附近安装探测器。

2. 防漏水和水灾

由于计算机系统使用电源,因此水对计算机的威胁也是致命的,它可以导致计算机设备短路,从而损害设备。所以,对机房必须采取防水措施。机房的防水措施应考虑如下几个方面。

(1) 与主机房无关的给排水管道不得穿过主机房。

(2) 主机房内如设有地漏,地漏下应加设水封装置,并有防止水封破坏的措施。

(3) 机房内的设备需要用水时,其给排水干管应暗敷,引入支管宜暗装。管道穿过主机房墙壁和楼板处,应设置套管,管道与套管之间应采取可靠的密封措施。

(4) 机房不宜设置在用水设备的下层。

(5) 机房房顶和吊顶应有防渗水措施。

(6) 安装排水地漏处的楼地面应低于机房内的其他楼地面。

3. 防静电

机房的防静电应考虑以下防范措施。

(1) 接地系统良好与否是衡量一个机房建设质量的关键性问题之一,因此接地系统应满足《电子计算机机房设计规范》(GB 50174-93)的规定。

(2) 主机房地面及工作台面的静电泄漏电阻,应符合现行国家标准《计算机机房用活动地板技术条件》的规定。

(3) 主机房内绝缘体的静电电位不应大于 1kV 。

4. 防自然灾害

自然界存在着种种不可预测或者虽可预料却不能避免的灾害,例如洪水、地震、大风和火山爆发等。对此,应积极应对,制定一套完善的应对措施;建立合适的检测方法和手段,以期尽可能早地发现这些灾害的发生,采取一定的预防措施。例如,采用避雷

措施以规避雷击，加强建筑的抗震等级以尽量对抗地震造成的危害。因此，应当预先制定好相应的对策，包括在灾害来临时采取行动的步骤和灾害发生后的恢复工作等。通过对不可避免的自然灾害事件制定完善的计划和预防措施，使系统受到损失的程度降到最小。同时，对于重要的信息系统，应当考虑在异地建立适当的备份和灾难恢复系统。

5. 防物理安全威胁

在实际生活中，除了自然灾害外，还存在种种其他的情况威胁着计算机系统的物理安全。例如，通信线路被盗窃者割断，就可以导致网络中断。如果周围有化工厂，若是化工厂发生有毒气体泄露，就会腐蚀和污染计算机系统。再如，2001年9月11日美国发生的纽约世贸大楼被撞恐怖事件，导致大楼起火倒塌，不仅许多无辜生命死亡，里面的计算机系统也不可避免地遭受破坏。对于种种威胁，计算机安全管理部门都应该有一个清晰的认识。

17.3.4 电磁兼容

1. 计算机设备防泄露

对需要防止电磁泄露的计算机设备应配备电磁干扰设备，在被保护的计算机设备工作时电磁干扰设备不准关机；必要时可以采用屏蔽机房。屏蔽机房应随时关闭屏蔽门；不得在屏蔽墙上打钉钻孔，不得在波导管以外或不经过滤器对屏蔽机房内外连接任何线缆；应经常测试屏蔽机房的泄露情况并进行必要的维护。

2. 计算机设备的电磁辐射标准和电磁兼容标准

计算机设备的电磁辐射标准和电磁兼容标准很多，主要列举如下。

(1) GB 17625.2-1999 电磁兼容限值对额定电流不大于16A的设备在低压供电系统中产生的电压波动和闪烁的限制。

(2) GB/T 17625.3-2000 电磁兼容限值对额定电流大于16A的设备在低压供电系统中产生的电压波动和闪烁的限制。

(3) GB/T 17626.11-1999 电磁兼容试验和测量技术电压暂降、短时中断和电压变化的抗扰度试验。

(4) GB 4943-1995 信息技术设备（包括电气事务设备）的安全。

(5) GB 9254-1988 信息技术设备的无线电干扰极限值和测量方法。

(6) GB/T 17618-1998 信息技术设备抗扰度限值和测量方法。

(7) GB/T 17625.1-1998 低压电气及电子设备发出的谐波电流限值（设备每相输入电流6A）。

(8) GB/T 2887-2000 计算机场地通用规范。

(9) GB 50174-1993 电子计算机房设计规范。

(10) GA 173-98 计算机信息系统防雷保安器。

(11) GGBB 1-1999 计算机信息系统设备电磁泄漏发射限值。

- (12) GGBB 2-1999 计算机信息系统设备电磁泄漏发射测试方法。
- (13) BMB 1-94 电话机电磁泄漏发射限值及测试方法。
- (14) BMB 2-1998 使用现场的信息设备电磁泄漏发射测试方法和安全判据。
- (15) BMB 3-1999 处理涉密信息的电磁屏蔽室的技术要求和测试方法。
- (16) BMB 4-2000 电磁干扰器技术要求和测试方法。
- (17) BMB 5-2000 涉密信息设备使用现场的电磁泄漏发射防护要求。
- (18) BMB 6-2001 密码设备电磁泄漏发射限值。
- (19) BMB 7-2001 密码设备电磁泄漏发射测试方法（总则）。
- (20) BMB 7.1-2001 电话机电磁泄漏发射测试方法。
- (21) GGB 1-1999 信息设备电磁泄漏发射限值。
- (22) GGBB 2-1999 信息设备电磁泄漏发射测试方法。

17.4 人员安全管理

17.4.1 安全组织

安全组织的目的在于通过建立管理框架，以启动和控制组织范围内的信息安全的实施。

管理者应通过清晰的方向、说明性承诺、明确的信息安全职责分配和确认，来积极支持组织内的安全。管理者并应批准整个组织内的信息安全方针、分配安全角色并协调和评审安全的实施。

组织可建立信息安全领导小组，负责本组织机构的信息系统安全工作，并至少履行以下职能。

(1) 安全管理的领导职能：根据国家和行业有关信息安全的政策、法律和法规，批准机构信息系统的安全策略和发展规划；确定各有关部门在信息系统安全中的职责，领导安全工作的实施；监督安全措施的执行，并对重要安全事件的处理进行决策；指导和检查信息系统安全职能部门和应急处理小组的各项工作；建设和完善信息系统安全的集中控管的组织体系和管理机制。

(2) 保密监督的管理职能：在上述基础上，对保密管理部门进行有关信息系统安全保密监督管理方面的指导和检查。

组织可建立信息安全职能部门，在信息安全领导小组监管下，负责本组织机构信息系统安全的具体工作，至少履行以下管理职能之一。

(1) 基本的安全管理职能：根据国家和行业有关信息安全的政策法规，起草组织机构信息系统的安全策略和发展规划；管理机构信息系统安全日常事务，检查和指导下级单位信息系统安全工作；负责安全措施的实施或组织实施，组织并参加对安全重要事件

的处理；监控信息系统安全总体状况，提出安全分析报告；指导和检查各部门和下级单位信息系统安全人员及要害岗位人员的信息系统安全工作；应与有关部门共同组成应急处理小组或协助有关部门建立应急处理小组，并实施相关应急处理工作。

（2）集中的安全管理职能：在上述基础上，管理信息系统安全机制集中管理机构的各项工作，实现信息系统安全的集中控制管理；完成信息系统安全领导小组交办的工作，并向领导小组报告机构的信息系统安全工作。

如果需要，要在组织范围内建立信息安全专家建议的资料源，并在整个组织内均可获得该资料。要发展与外部安全专家或组织（包括相关权威人士）的联系，以便跟上行业发展趋势、跟踪标准和评估方法，并且当处理信息安全事故时，提供合适的联络地点。应鼓励构建信息安全的多学科交叉途径。

17.4.2 岗位安全考核与培训

对信息系统岗位人员的管理，应根据其关键程度建立相应的管理要求。

（1）对安全管理员、系统管理员、数据库管理员、网络管理员、重要业务开发人员、系统维护人员和重要业务应用操作人员等信息系统关键岗位人员进行统一管理；允许一人多岗，但业务应用操作人员不能由其他关键岗位人员兼任；关键岗位人员应定期接受安全培训，加强安全意识和风险防范意识。

（2）兼职和轮岗要求：业务开发人员和系统维护人员不能兼任或担负安全管理员、系统管理员、数据库管理员、网络管理员和重要业务应用操作人员等岗位或工作；必要时关键岗位人员应采取定期轮岗制度。

（3）权限分散要求：在上述基础上，应坚持关键岗位“权限分散、不得交叉覆盖”的原则，系统管理员、数据库管理员、网络管理员不能相互兼任岗位或工作。

（4）多人共管要求：在上述基础上，关键岗位人员处理重要事务或操作时，应保持二人同时在场，关键事务应多人共管。

（5）全面控制要求：在上述基础上，应采取对内部人员全面控制的安全保证措施，对所有岗位工作人员实施全面安全管理。

17.4.3 离岗人员安全管理

对人员离岗的管理，可以根据离岗人员的关键程度，采取下列控制措施。

（1）基本要求：立即中止被解雇的、退休的、辞职的或其他原因离开的人员的所有访问权限；收回所有相关证件、徽章、密钥和访问控制标记等；收回机构提供的设备等。

（2）调离后的保密要求：在上述基础上，管理层和信息系统关键岗位人员调离岗位，必须经单位人事部门严格办理调离手续，承诺其调离后的保密要求。

（3）离岗的审计要求：在上述基础上，涉及组织机构管理层和信息系统关键岗位的人员调离单位，必须进行离岗安全审查，在规定的脱密期限后，方可调离。

(4) 关键部位人员的离岗要求：在上述基础上，关键部位的信息系统安全管理人员离岗，应按照机要人员管理办法办理。

17.5 应用系统安全管理

17.5.1 应用系统安全管理的实施

1. 建立应用系统的安全需求管理

安全控制需求规范应考虑在系统中所包含的自动化控制以及人工控制的需要。在评价应用系统的开发或购买时，需要进行安全控制的考虑。安全要求和控制反映出所涉及信息资产的业务价值和潜在的业务损坏，这可能是由于安全功能失败或缺少安全功能引起的。信息安全系统需求与实施安全的过程应该在信息安全工程的早期阶段集成。在设计阶段引入控制其实施和维护的费用明显低于实现期间或实现后所包含的控制费用。

2. 严格应用系统的安全检测与验收

对软件的安全检测与验收主要可依据 GB/T 18336.1-2008《信息技术 安全技术 信息技术安全性评估准则 第 1 部分：简介和一般模型》、GB/T 18336.2-2008《信息技术 安全技术 信息技术安全性评估准则第 2 部分：安全功能要求》以及 GB/T 18336.3-2008《信息技术 安全技术 信息技术安全性评估准则第 3 部分：安全保证要求进行》。

在安全功能要求方面，可以对软件的安全审计功能、通信功能（包括原发抗抵赖和接收抗抵赖）、密码支持功能、用户数据保护功能、标识和鉴别功能、安全管理功能、隐私功能、TSF 保护功能、资源利用功能、TOE 访问功能、可信路径/信道功能等 11 个方面进行检测和验收。

3. 加强应用系统的操作安全控制

应用系统内设计合适的控制以确保处理的正确性。这些控制包括输入数据的验证、内部处理控制和输出数据的确认。对于处理敏感的、有价值的或关键的组织资产的系统或对组织资产有影响的系统可以要求附加控制。这样的控制应在安全要求和风险评估的基础上加以确定。

4. 规范变更管理

为使信息系统的损坏程度减到最小，应实施正式的变更控制规程。变更的实施要确保不损坏安全和控制规程，并将变更控制规程文档化，引进新的系统和对已有系统进行大的变更要按照从文档、规范、测试、质量管理到实施管理这个过程进行。

变更管理过程应包括风险评估、变更效果分析和安全控制。确保变更不损坏安全和控制规程，确保支持性程序员仅能访问其工作所需的系统的某些部分，确保对任何变更要获得正式协商和批准。

5. 防止信息泄露

为了限制信息泄露的风险，如通过应用隐蔽通道泄露信息，可以考虑扫描隐藏信息的外部介质和通信，掩盖和调整系统和通信的行为，以减少第三方访问信息或推断信息的能力；使用可信赖的应用系统和软件进行信息处理；在法律和法规允许的前提下，定期监视个人系统的行为，监视计算机系统的源码使用。

6. 严格访问控制

严格控制对应用系统的访问，包括如下方面。

(1) 建立访问控制策略，并根据对访问的业务和安全要求进行评审，访问策略清晰地叙述每个用户或一组用户的访问控制规则和权利，访问控制既有逻辑的也是物理的控制方法。

(2) 建立正式的授权程序来控制对应用系统和服务的访问权力的分配，确保授权用户的访问，并预防对信息系统的非授权访问。程序应涵盖用户访问生存周期内的各个阶段，从新用户注册到不再要求访问信息系统和用户的最终注销。应特别注意对有特权的访问权力的分配的控制需要，因为这种特殊权限可导致用户超越系统控制而进行系统操作。

(3) 避免未授权用户的信息访问和信息处理设施，要让用户了解他对维护有效的访问控制的职责，特别是关于口令的使用和用户设备的安全的职责。

(4) 如果具有合适的安全设计和控制并且符合组织的安全策略，组织才能授权远程工作活动。远程工作场地的合适保护应到位，以防止偷窃设备和信息、未授权泄露信息、未授权远程访问组织内部系统或滥用设施等。远程工作要由管理层授权和控制以及对远程工作方法要有充分的安排。

7. 信息备份

制定应用系统的备份策略，根据策略对信息和软件进行备份并定期测试。提供足够的备份设施，保持信息和信息处理设施的完整性和可用性，确保所有必要的信息和软件能在灾难或介质故障后进行恢复。建立例行程序来执行针对数据备份以及恢复演练的策略和战略。

8. 应用系统的使用监视

检测未经授权的信息处理活动，记录用户活动、异常和信息安全事件的日志，并按照约定的期限进行保留，以支持将来的调查和访问控制监视。记录系统管理员和系统操作者的活动，并对系统管理员和操作员的日志定期评审。记录并分析错误日志，并采取适当的措施改正错误。

17.5.2 应用系统运行中的安全管理

1. 组织管理层在系统运行安全管理中的职责

管理层对应用系统的安全负有全部责任。安全管理包括：

- (1) 资源分配：管理层负责为计划内的应用系统的安全活动提供必要的资源。
- (2) 标准和程序：管理层负责为所有运行建立必要的符合总体业务战略和政策的的标准和程序，并符合组织业务的安全规定。
- (3) 应用系统的过程监控：应用系统管理人员要负责监控和测量应用系统运行过程的效率与效果，以保证过程的持续完善。

2. 系统运行安全的审查目标

系统运行安全的审查目标如下。

- (1) 保证应用系统运行交接过程均有详尽的安排。
- (2) 精心计划以确保运行资源得到最有效的使用。
- (3) 对运行日程的变更进行授权。
- (4) 监控系统运行以确保其符合标准。
- (5) 监控环境和设施的安全，为设备的正常运行保持适当的条件。
- (6) 检查操作员日志以识别预定的和实际的活动之间的差异。
- (7) 监控系统性能和资源情况，以实现计算机资源的最佳使用。
- (8) 预测设备或应用系统的容量，以保证当前作业流量的最大化并为未来需求制定战略计划。

3. 系统运行安全与保密的层次构成

应用系统运行中涉及的安全和保密层次包括系统级安全、资源访问安全、功能性安全、数据域安全。这 4 个层次的安全，按粒度从大到小的排序是：系统级安全、资源访问安全、功能性安全、数据域安全。程序资源访问控制安全的粒度大小介于系统级安全和功能性安全两者之间，是最常见的应用系统安全问题，几乎所有的应用系统都会涉及这个安全问题。

1) 系统级安全

企业应用系统越来越复杂，因此制定得力的系统级安全策略才是从根本上解决问题的基础。应通过对现行系统安全技术的分析，制定系统级安全策略，策略包括敏感系统的隔离、访问 IP 地址段的限制、登录时间段的限制、会话时间的限制、连接数的限制、特定时间段内登录次数的限制以及远程访问控制等，系统级安全是应用系统的第一道防护大门。

2) 资源访问安全

对程序资源的访问进行安全控制，在客户端上，为用户提供与其权限相关的用户界面，仅出现与其权限相符的菜单和操作按钮；在服务端则对 URL 程序资源和业务服务类方法的调用进行访问控制。

3) 功能性安全

功能性安全会对程序流程产生影响，如用户在操作业务记录时，是否需要审核，上传附件不能超过指定大小等。这些安全限制已经不是入口级的限制，而是程序流程内的

限制，在一定程度上影响程序流程的运行。

4) 数据域安全

数据域安全包括两个层次，其一，是行级数据域安全，即用户可以访问哪些业务记录，一般以用户所在单位为条件进行过滤；其二，是字段级数据域安全，即用户可以访问业务记录的哪些字段。不同的应用系统数据域安全的需求存在很大的差别，业务相关性比较高。对于行级的数据域安全，大致可以分为以下几种情况：

(1) 应用组织机构模型允许用户访问其所在单位及下级管辖单位的数据。

(2) 通过数据域配置表配置用户有权访问的同级单位及其他行政分支下的单位的数据。

(3) 按用户进行数据安全控制，只允许用户访问自己录入或参与协办的业务数据。

(4) 除进行按单位过滤之外，比较数据行安全级别和用户级别，只有用户的级别大于等于行级安全级别，才能访问到该行数据。

4. 系统运行安全检查与记录

系统运行的安全检查是安全管理的常用工作方法，也是预防事故、发现隐患、指导整改的必要工作手段。系统运行安全检查要形成制度，对促进系统运行管理、实现信息安全起到积极的推动和保障作用。对检查的内容、检查的方法、检查的计划安排、检查的结果应进行及时的记录、分析和评审。系统运行安全检查和记录的范围如下。

(1) 应用系统的访问控制检查，包括物理和逻辑访问控制，是否按照规定的策略和程序进行访问权限的增加、变更和取消，用户权限的分配是否遵循“最小特权”原则。

(2) 应用系统的日志检查，包括数据库日志、系统访问日志、系统处理日志、错误日志及异常日志。

(3) 应用系统可用性检查，包括系统中断时间、系统正常服务时间和系统恢复时间等。

(4) 应用系统能力检查，包括系统资源消耗情况、系统交易速度和系统吞吐量等。

(5) 应用系统的安全操作检查。用户对应用系统的使用是否按照信息安全的相关策略和程序进行访问和使用。

(6) 应用系统维护检查。维护性问题是否在规定的时间内解决，是否正确地解决问题，解决问题的过程是否有效等。

(7) 应用系统的配置检查。检查应用系统的配置是否合理和适当，各配置组件是否发挥其应有的功能。

(8) 恶意代码的检查。是否存在恶意代码，如病毒、木马、隐蔽通道导致应用系统数据的丢失、损坏、非法修改、信息泄露等。

企业要加强对应用系统安全运行管理工作的领导，每年至少组织有关部门对系统运行工作进行一次检查。部门每季度进行一次自查。要加强对所辖范围内应用系统运行工作的监督检查。检查可采取普查、抽查、专项检查的方式定期或不定期地进行。

有关部门检查时要事先拟定检查提纲,检查项目的指标要量化。检查后要进行总结,检查结果要及时通报,对检查中发现的问题,要限期改进。

5. 系统运行安全管理制度

系统运行安全管理制度是系统管理的一个重要内容。它是确保系统按照预定目标运行并充分发挥其效益的必要条件、运行机制和保障措施。通常它应该包括如下内容。

1) 系统运行的安全管理组织

它包括各类人员的构成、各自职责、主要任务和管理内部组织结构。建立系统运行的安全管理组织,安全组织由单位主要领导人领导,不能隶属于计算机运行或应用部门。安全组织由管理、系统分析、软件、硬件、保卫、审计、人事和通信等有关方面人员组成。安全负责人负责安全组织的具体工作,安全组织的任务是根据本单位的实际情况定期做风险分析,提出相应的对策并监督实施。

2) 系统运行的安全管理

制定有关的政策、制度、程序或采用适当的硬件手段、软件程序和技术工具,保证信息系统不被未经授权进入和使用、修改、盗窃等造成损害的各种措施。

(1) 系统安全等级管理

根据应用系统所处理数据的秘密性和重要性确定安全等级,并据此采用有关规范和制定相应管理制度。安全等级可分为保密等级和可靠性等级两种,系统的保密等级与可靠性等级可以不同。保密等级应按有关规定划为绝密、机密和秘密。可靠性等级可分为三级,对可靠性要求最高的为 A 级,系统运行所要求的最低限度可靠性为 C 级,介于中间的为 B 级。安全等级管理就是根据信息的保密性及可靠性要求采取相应的控制措施,以保证应用系统及数据在既定的约束条件下合理合法的使用。

(2) 系统运行监视管理

重要应用系统投入运行前,可请公安机关的计算机监察部门进行安全检查。根据应用系统的重要程度,设立监视系统,分别监视设备的运行情况或工作人员及用户的操作情况,或安装自动录像等记录装置。

(3) 系统运行文件管理制度

制定严格的技术文件管理制度,应用系统的技术文件如说明书、手册等应妥善保存,要有严格的借阅手续,不得损坏及丢失。系统运行维护时备有应用系统操作手册规定的文件。应用系统出现故障时可查询替代措施和恢复顺序所规定的文件。

(4) 系统运行操作规程

通过制定规范的系统操作程序,用户严格按照操作规程使用应用系统。应用系统操作人员应为专职,关键操作步骤要有两名操作人员在场,必要时需要对操作的结果进行检查和复核。对系统开发人员和系统操作人员要进行职责分离。制定系统运行记录编写制度,系统运行记录包括系统名称、姓名、操作时间、处理业务名称、故障记录及处理情况等。

（5）用户管理制度

建立用户身份识别与验证机制，防止非授权用户进入应用系统。对用户及其权限的设定应进行严格管理，用户权限的分配必须遵循“最小特权”原则。用户密码应严格保密，并及时更新。重要用户密码应密封交安全管理员保管，人员调离时应及时修改相关密码和口令。

（6）系统运行维护制度

必须制定有关电源设备、空调设备和防水防盗消防等防范设备的管理规章制度，确定专人负责设备维护和制度实施。对系统进行维护时，应采取数据保护措施。如数据转贮、抹除、卸下磁盘磁带，维护时安全人员必须在场等待。远程维护时，应事先通知。对系统进行预防维护或故障维护时，必须记录故障原因、维护对象、维护内容和维护前后状况等。

（7）系统运行灾备制度

系统重要的信息和数据应定期备份，针对系统运行过程中可能发生的故障和灾难，制定恢复运行的措施、方法，并成立应急计划实施小组，负责应急计划的实施和管理。在保证系统正常运行的前提下，对可模拟的故障和灾难每年至少进行一次实施应急计划的演习。应急计划的实施必须按规定由有关领导批准，实施后，有关部门必须认真分析和总结事故原因，制定相应的补救和整改措施。

（8）系统运行审计制度

定期对应用系统的安全审计跟踪记录及应用系统的日志进行检查和审计，检查非授权访问及应用系统的异常处理日志。根据系统的配置信息和运行状况，分析系统可能存在的安全隐患和漏洞，对发现的隐患和漏洞要及时研究补救措施，并报相关部门领导审批后实施。

3) 系统运行的安全监督

应用系统的使用单位，通过建立应用系统安全保护领导组织或配备专兼职管理人员，落实安全保护责任制度，对管理人员和应用操作人员组织岗位培训；制定防治计算机病毒和其他有害数据的方案，必要时协助公安机关查处危害计算机信息系统安全的违法犯罪案件。

根据应用系统的运行特点，制定系统运行安全监督制度，包括：

- （1）对应用系统安全保护工作实施监督、检查、指导。
- （2）监督检查用户是否按照规定的程序和方法使用应用系统和处理信息。
- （3）开展应用系统运行安全保护的宣传教育工作。
- （4）查处危害应用系统安全的信息安全事件。
- （5）对应用系统的设计、变更、扩建工程进行安全指导。
- （6）管理计算机病毒和其他有害数据的防治工作。
- （7）按有关规定审核计算机信息系统安全等级，并对信息系统的合法使用进行检查。

(8) 根据有关规定,履行应用系统安全保护工作的其他监督职责。

4) 系统运行的安全教育

根据应用系统所设计的业务范围,对管理层、系统管理员和操作人员等用户进行信息安全的教育培训,培训包括:

- (1) 管理层信息安全忧患意识的培养;
- (2) 正确合法地使用应用系统的程序培训;
- (3) 员工上岗信息安全知识培训;
- (4) 各岗位人员计算机安全意识和法律意识教育情况;
- (5) 安全从业人员安全防护知识的培训。

制定系统运行安全的培训管理程序和安全培训计划,程序规定培训的范围、启动、制定培训计划、培训计划的实施、培训效果的考核、评审和验证等。培训计划的内容包括培训对象、培训内容、日程安排、培训要求和考核方法等要素。

17.6 信息安全等级保护

为规范信息安全等级保护管理,提高信息安全保障能力和水平,维护国家安全、社会稳定和公共利益,保障和促进信息化建设,根据《中华人民共和国计算机信息系统安全保护条例》等有关法律法规,公安部、国家保密局、国家密码管理局、国务院信息化工作办公室于2007年6月制定了《信息安全等级保护管理办法》。

国家信息安全等级保护坚持自主定级、自主保护的原则。信息系统的安全保护等级应当根据信息系统在国家安全、经济建设、社会生活中的重要程度,信息系统遭到破坏后对国家安全、社会秩序、公共利益以及公民、法人和其他组织的合法权益的危害程度等因素确定。

《信息安全等级保护管理办法》将信息系统的安全保护等级分为以下五级。

第一级,信息系统受到破坏后,会对公民、法人和其他组织的合法权益造成损害,但不损害国家安全、社会秩序和公共利益。第一级信息系统运营、使用单位应当依据国家有关管理规范和技术标准进行保护。

第二级,信息系统受到破坏后,会对公民、法人和其他组织的合法权益产生严重损害,或者对社会秩序和公共利益造成损害,但不损害国家安全。第二级信息系统运营、使用单位应当依据国家有关管理规范和技术标准进行保护。国家信息安全监管部门对该级信息系统信息安全等级保护工作进行指导。

第三级,信息系统受到破坏后,会对社会秩序和公共利益造成严重损害,或者对国家安全造成损害。第三级信息系统运营、使用单位应当依据国家有关管理规范和技术标准进行保护。国家信息安全监管部门对该级信息系统信息安全等级保护工作进行监督、检查。

第四级，信息系统受到破坏后，会对社会秩序和公共利益造成特别严重损害，或者对国家安全造成严重损害。第四级信息系统运营、使用单位应当依据国家有关管理规范、技术标准和业务专门需求进行保护。国家信息安全监管部门对该级信息系统信息安全等级保护工作进行强制监督、检查。

第五级，信息系统受到破坏后，会对国家安全造成特别严重损害。第五级信息系统运营、使用单位应当依据国家管理规范、技术标准和业务特殊安全需求进行保护。国家指定专门部门对该级信息系统信息安全等级保护工作进行专门监督、检查。

《信息安全等级保护管理办法》明确规定，在信息系统建设过程中，运营、使用单位应当按照《计算机信息系统安全保护等级划分准则》（GB 17859-1999）、《信息系统安全等级保护基本要求》等技术标准，参照《信息安全技术信息系统通用安全技术要求》（GB/T 20271-2006）、《信息安全技术网络基础安全技术要求》（GB/T 20270-2006）、《信息安全技术操作系统安全技术要求》（GB/T 20272-2006）、《信息安全技术数据库管理系统安全技术要求》（GB/T 20273-2006）、《信息安全技术服务器技术要求》、《信息安全技术终端计算机系统安全等级技术要求》（GA/T 671-2006）等技术标准同步建设符合该等级要求的信息安全设施。

GB 17859-1999 标准是计算机信息系统安全等级保护系列标准的核心，是施行计算机信息系统安全等级保护制度建设的重要基础。GB 17859-1999 标准规定了计算机系统安全保护能力的五个等级，即：用户自主保护级、系统审计保护级、安全标记保护级、结构化保护级、访问验证保护级。

第 18 章 项目风险管理

18.1 风险概述

18.1.1 风险的定义

风险的定义有广义、狭义之分。狭义的风险定义为损失的不确定性，而广义的风险定义为带来损失的可能性，也指可能获利的机会。狭义的风险表现为负面的影响，而广义的风险是一个中性词，表示在损失、获益之间的任意一种可能。本书采用广义的风险概念：风险是一种不确定的事件或条件，一旦发生，就会产生积极或消极的影响。在企业管理中我们所说的风险通常是指由于激烈竞争的环境以及技术条件的改变，企业管理面临的不确定性。

当风险发生时，不同的企业被影响的程度不同，比如当索尼的 WalkMan 出现后，传统的唱片制造业承受了巨大的打击，从历史舞台的中央逐渐边缘化。当数码相机出现后，拒绝改变或者改变迟缓的企业纷纷倒闭，而那些新兴的企业或者转型快速的企业抓住机会获利颇丰。

风险可以用概率表示（在这里用 p 表示）其发生的可能性，我们认为当概率等于 0% 时，这个风险肯定不会发生，反之当概率等于 100% 时，我们认为它一定会发生。风险的发生是不确定的，在本书中，风险的发生的概率在 0% 到 100% 这个开区间内。

18.1.2 风险的分类

风险可以根据性质、标的、行为、产生的环境以及产生的原因进行分类，在不同的行业、不同的时间段（和点）、不同的人根据自己的实际需要风险进行分类并加以区分。

1. 按照性质划分

1) 纯粹风险

纯粹风险是指只有损失可能性而无获利可能性的风险。比如房屋所有者面临的火灾风险、汽车主人面临的碰撞风险等。当火灾碰撞事故这样的纯粹风险发生时，他们便会遭受经济利益上的损失。

2) 投机风险

投机风险是相对于纯粹风险而言的，是指既有损失的可能又有获利机会的风险。投机风险的后果一般有三种：一是没有损失；二是有损失；三是收益。比如在股票市场上

买卖股票,就存在赚钱、赔钱、不赔不赚三种后果,因而属于投机风险。

2. 按照产生原因划分

1) 自然风险

自然风险是指因自然力的不规则变化使社会生产和社会生活等遭受威胁的风险。如地震、风灾、水灾、火灾以及各种瘟疫等自然现象是经常的、大量发生的。在各类风险中,自然风险是保险人承保最多的风险。

自然风险的特征有:

- (1) 不可控性。比如地震、火山爆发是目前人类所不能进行控制的。
- (2) 周期性。如活火山的活跃周期是有规律可循的。
- (3) 共沾性。即自然风险事故一旦发生,其涉及的对象往往很广。

2) 社会风险

社会风险是指由于个人或团体的行为(包括过失行为、不当行为以及故意行为)或不作为使社会生产以及人们生活遭受损失的风险。如盗窃、抢劫、玩忽职守及故意破坏等行为将可能对他人财产造成损失或人身造成伤害。

3) 政治风险(国家风险)

政治风险是指在对外投资和贸易过程中,因政治原因或订立双方所不能控制的原因,使债权人可能遭受损失的风险。如因进口国发生战争、内乱而中止货物进口,因进口国实施进口或外汇管制等等。

4) 经济风险

经济风险是指在生产和销售等经营活动中由于受各种市场供求关系、经济贸易条件等因素变化的影响或经营者决策失误,对前景预期出现偏差等导致经营失败的风险。比如企业生产规模的增减、价格的涨落和经营的盈亏等。

5) 技术风险

技术风险是指伴随着科学技术的发展、生产方式的改变而产生的威胁人们生产与生活的风险。如核辐射、空气污染和噪音等。

对于风险的分类,有的时候还可以按照标的物划分,如:财产风险、人身风险、责任风险、信用风险;有的时候按照行为划分,如:特定风险和基本风险;有的时候按照环境划分,如:静态风险和动态风险等。

18.1.3 风险的性质

风险具有以下特性。

1) 客观性

风险是一种不以人的意志为转移,独立于人的意识之外的客观存在。因为无论是自然界的物质运动,还是社会发展的规律,都由事物的内部因素所决定。由超过人们主观意识所存在的客观规律所决定。

2) 偶然性

由于信息的不对称,未来风险事件发生与否难以预测。

3) 相对性

风险性质会因时空各种因素变化而有所变化。

4) 社会性

风险的后果与人类社会的相关性决定了风险的社会性,具有很大的社会影响力。

5) 不确定性

发生时间的不确定性。从总体上看,有些风险是必然要发生的,但何时发生却是不确定性的。例如,生命风险中,死亡是必然发生的,这是人生的必然现象,但是具体到某一个人何时死亡,在其健康时却是不能确定的。

风险管理不是一蹴而就的,不能简单地认为管理好一个风险就能达到目标。因为在管理的过程中,各种各样的因素同时发生作用,比如时间、社会、政治、经济等因素,都在发挥着各自的作用。管理者需要认真的考察、分析,并做出最终的结论。有的时候,一个风险被管理后,可能会引发更大更多的风险,导致更多的不确定性发生。管理者是否需要和是否有能力对风险进行管理,需要在认真分析风险的基础上做出准确的判断后再进行决断。

有的时候,人们会对风险进行一定的管理,对风险发生的几率进行判断,同时为可能出现的风险导致的损失和收益进行准备。如每年政府有关部门会从气象部门获取未来一段时间的气象预测。即便没有证据表明当年的气象肯定会出现大的灾害,也应当提前提出预案进行准备,同时划拨一定的资金为灾害处理时使用。如果当年气象条件可能没有大的灾害发生,则有关部门需要制定如何增加粮食收购和存储的人员,以及仓库、运输等计划。

18.2 项目风险管理

传统的风险关注的是负面的影响,也就是“损失”发生的可能性。在本书中,我们提到的风险是广义风险,除非特别指明,狭义的风险会以“损失”代替,而且风险影响的范围限定在企业内部。

IT领域中的项目风险管理直接关系到项目的成功和失败。风险管理常常被管理者忽视,导致项目的实施过程中经常充满不确定性,使项目的成功率下降。Ibbs, C. Williams 和 Young Hoon Kwak 在 2000 年 3 月发表的文章中(“Assessing Project Management” Project Management Journal (March 2000))提到,他们调查了 38 个组织,这些组织按照工程/建设、电信、信息系统和高科技制造分为四个组别。调查方式采用问卷方式,每个组织需要回答 148 个多项选择题,评估组织在项目管理各知识领域的成熟度,比如范围、时间、成本、质量、人力资源、沟通、风险和采购等。分数从 1 至 5,5 代表最高成熟度。

根据调查的结果，发现风险管理是唯一所有等级分数小于3的知识领域，而且信息系统（包括软件开发）行业，得分最低，为2.75。

知识领域	工程/建筑	电信	信息系统	高科技制造
范围	3.52	3.45	3.25	3.37
时间	3.55	3.41	3.03	3.50
成本	3.74	3.22	3.20	3.97
质量	2.91	3.22	2.88	3.26
人力资源	3.18	3.20	2.93	3.18
沟通	3.53	3.53	3.21	3.48
风险	2.93	2.87	2.75	2.76
采购	3.33	3.01	2.91	3.33

对于带来负面损失的风险进行管理就是为了减轻对项目实施的不利影响而采取的活动，对于带来机会收益的风险进行管理就是为了更好的完成项目的目标而采取的活动。

在进行项目风险管理的时候，会发生一定的成本，而风险管理所花费的成本不能超过所管理的风险事件的预期货币价值。如一个风险发生时如果可能对项目造成20000元的损失，进行相应的管理后，该风险的损失会减少到5000元，而我们花费的成本如果超过15000元，在不考虑其他因素的前提下，就应该考虑任其发生而不进行管理。如果一个风险发生时，给项目带来成本减少20000元，而制造这个正面的风险如果需要花费超过20000元的成本，则这个风险所创造的机会也不值得进行管理。在后面小节中对于项目风险进行识别、定性分析以及定量分析中会利用各种方法和工具为项目经理提供依据。

项目风险管理包括规划风险管理、识别风险、实施风险分析、规划风险应对和控制风险等各个过程。项目风险管理的目标在于提高项目中积极事件的概率和影响，降低项目中消极事件的概率和影响。

1. 规划风险管理

它是定义如何实施项目风险管理活动的过程。

2. 识别风险

它是判断哪些风险可能影响项目并记录其特征的过程。

3. 实施定性风险分析

它是评估并综合分析风险的发生概率和影响，对风险进行优先排序，从而为后续分析或行动提供基础的过程。

4. 实施定量风险分析

它是就已识别风险对项目整体目标的影响进行定量分析的过程。

5. 规划风险应对

它是针对项目目标，制定提高机会、降低威胁的方案和措施的过程。

6. 控制风险

它是在整个项目中实施风险应对计划、跟踪已识别风险、监督残余风险、识别新风

险，以及评估风险过程有效性的过程。

进行项目风险管理的多个过程不仅彼此相互作用，而且还与其他知识领域中的过程相互作用。

项目风险是一种不确定的事件或条件，一旦发生，就会对一个或多个项目目标造成积极或消极的影响，如对范围、进度、成本和质量等造成影响。风险的发生可能由多种因素引起，一旦发生就可能造成一项或多项影响。风险的起因可以是已知或潜在的需求、假设条件、制约因素或某种状况，可能引起消极或积极结果。例如，项目需要先申请环境许可证，是否能够在不影响进度的前提下拿到许可就是一种风险，或者分配给项目的设计人员有限，而在项目实施中是否能够保证有足够的设计人员或者设计人员的水平超过预期，都可能成为风险起因。上述两个不确定性事件中，无论发生哪一个，都可能对项目的范围、成本、进度、质量或绩效产生影响。风险条件则是可能引发项目风险的各种项目或组织环境因素，如不成熟的项目管理实践、缺乏综合管理系统、多项目并行实施，或依赖不可控的外部参与者等。

任何项目中都存在不确定性。一般我们将已经识别并分析过的风险定义为已知风险，可对这些风险规划应对措施。对于那些已知但又无法主动管理的风险，要分配一定的应急储备。将在项目中没有被识别和分析过，但也有发生可能的风险定义为未知风险，未知风险是无法被主动管理的，因此需要分配一定的管理储备。已知风险和未知风险可以发生在项目生命周期中项目经理可控的因素内部，也可以是外部引发的各种因素，如项目团队成员突然决定离开项目组，而该成员的离开并没有在项目实施计划中被识别，或者政府部门突然颁布一个涉及到环境保护的法规。项目实施中已发生的消极的项目风险被视为问题，是一种损失如图 18-1 所示。



图 18-1 风险类别

单个项目风险不同于整体项目风险。整体项目风险代表不确定性对一个整体的项目的影响，它大于项目中单个风险之和，因为它包含了项目不确定性的所有来源。它代表了项目成果的变化可能给干系人造成的潜在影响，包括积极和消极的影响。

组织把风险看作不确定性给项目和组织目标造成的影响，基于不同的风险态度，组织和干系人愿意接受不同程度的风险。组织和干系人的风险态度受多种因素影响，这些因素大体可分为以下三类。

(1) 风险偏好。为了预期的回报，一个实体愿意承受不确定性的程度。

(2) 风险承受力。组织或个人能承受的风险程度、数量或容量。

(3) 风险临界值。干系人特别关注的特定的不确定性程度或影响程度。低于风险临界值，组织会接受风险；高于风险临界值，组织将不能承受风险。

例如，组织的风险态度可包括组织对不确定性的偏好程度、不可接受的风险级别的临界值、或者组织的风险承受力。组织会基于风险承受力而采取不同的风险应对措施。如果风险在组织可承受范围之内，并且与冒这些风险可能得到的回报相平衡，那么项目就是可接受的。在风险承受力允许的范围内，组织为了增加价值，追求那些能带来利益（机会）的积极风险，避免那些能够带来损失的消极风险。例如，为了减少资源使用量而采取激进的资源优化技术，或者为了减少政府罚款而改进空气净化设备。

个人和团体的风险态度影响其应对风险的方式。不同的个人和团体由于认知、承受力和各种成见的不同，对于风险的态度也不同。进行风险管理时，应该尽可能弄清楚他们的认知、承受力和成见。在制定项目管理计划时，项目经理应该为每个项目制定统一的风险管理方法，并开诚布公地就风险及其应对措施进行沟通。风险应对措施可以反映组织在冒险与避险之间的权衡。

要想取得成功，组织应致力于在整个项目期间积极、持续地开展风险管理。在整个项目的生命周期中，组织的各个层级都应该有意地积极识别并有效管理风险。项目从启动那一刻起，就存在风险。在项目推进过程中，如果不积极进行风险管理，那些未得到管理的威胁将引发更多问题。

18.3 规划风险管理

规划风险管理是定义如何实施项目风险管理活动的过程。本过程的主要作用是确保风险管理的程度、类型和可见度与风险及项目对组织的重要性相匹配。风险管理计划对促进与所有干系人的沟通，获得他们的同意与支持，从而确保风险管理过程在整个项目生命周期中有效实施是至关重要的。规划风险管理过程如图 18-2 所示。

认真地规划将提高项目风险管理其他过程的成功率，进而促进项目的成功。规划风险管理的重要性还在于为风险管理活动安排充足的资源和时间，并为评估风险奠定一个共同认可的基础。规划风险管理过程在项目构思阶段就应开始，在前面介绍项目整体管理中，如果已经在项目前期计划中设立的事项不会引起不必要的项目实施的不确定

性，不会增加额外的成本，也不会延缓项目进度等，但是风险的不确定性在很大程度上影响着项目的成败，所以，在项目规划的早期能够制定清晰、周密、完整的风险管理计划对于项目的成功有很大的帮助。

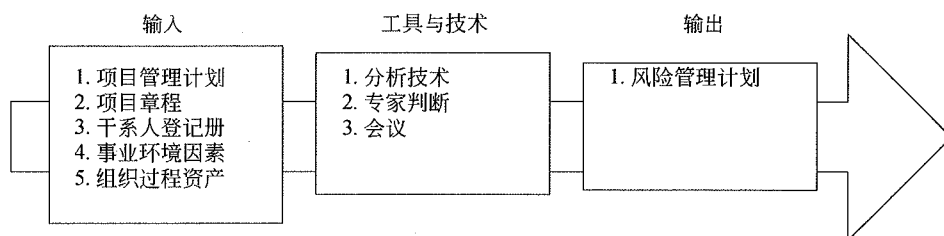


图 18-2 规划风险管理：输入、工具与技术和输出

18.3.1 规划风险管理的输入

1. 项目管理计划

在规划风险管理时，应该考虑所有已批准的子管理计划和基准，使风险管理计划与之相协调。风险管理计划也是项目管理计划的组成部分，项目管理计划提供了会受风险影响的范围、进度和成本的基准或当前状态。

2. 项目章程

项目章程可提供各种输入，如高层级风险、项目描述和需求。

3. 干系人登记册

干系人登记册包含了项目干系人的详细信息及角色概述。

4. 事业环境因素

能够影响规划风险管理过程的事业环境因素包括（但不限于）组织的风险态度、临界值和承受力，它们描述了组织愿意并能够承受的风险程度。

5. 组织过程资产

能够影响规划风险管理过程的组织过程资产包括（但不限于）：

- (1) 风险类别。
- (2) 概念和术语的通用定义。
- (3) 风险描述的格式。
- (4) 标准模板。
- (5) 角色和职责。
- (6) 决策所需的职权级别。
- (7) 经验教训。

18.3.2 规划风险管理的工具与技术

1. 分析技术

分析技术用来理解和定义项目的总体风险管理环境。风险管理环境是基于项目总体情况的干系人风险态度和项目战略风险敞口的组合。例如，可以通过对干系人风险资料的分析，确定干系人的风险偏好和承受力的等级与性质。其他技术，如战略风险计分表，用来基于项目总体情况概要地评估项目的风险敞口。基于这些评估，项目团队可以调配合适资源并关注风险管理活动。

2. 专家判断

为了编制全面的风险管理计划，应该征求那些具备特定培训经历或专业知识的小组或个人的意见，例如：

- (1) 高层管理者。
- (2) 项目干系人。
- (3) 曾在相同领域项目上工作的项目经理（直接或间接的经验教训）。
- (4) 特定业务或项目领域的主题专家。
- (5) 行业团体和顾问。
- (6) 专业技术协会。

3. 会议

项目团队举行规划会议，来制定风险管理计划。参会者可包括项目经理、选定的项目团队成员和干系人、组织中负责管理风险规划和应对活动的任何人员，以及需要参加的其他人员。

会议确定实施风险管理活动的内容包括：

- (1) 总体计划。
- (2) 管理成本和进度活动，分别将其纳入项目预算和进度计划中。
- (3) 建立或评审风险应急储备使用方法。
- (4) 分配风险管理职责。
- (5) 制定模板和术语，裁剪组织中有关风险类别和术语定义等通用模板，如风险级别、不同风险的概率、对不同目标的影响，以及概率和影响矩阵。

这些活动的输出将汇总在风险管理计划中。

18.3.3 规划风险管理的输出

风险管理计划是项目管理计划的组成部分，描述将如何安排与实施风险管理活动。风险管理计划包括以下内容。

1) 方法论

确定项目风险管理将使用的方法、工具及数据来源。

2) 角色与职责

确定风险管理计划中每个活动的责任者和支持者，以及风险管理团队的成员，并明确其职责。

3) 预算

根据分配的资源估算所需资金，并将其纳入成本基准，制定应急储备和管理储备的使用方案。

4) 时间安排

确定在项目生命周期中实施风险管理过程的时间和频率，制定进度应急储备的使用方案，确定风险管理活动并纳入项目进度计划中。

5) 风险类别

规定对潜在风险成因的分类方法。有多种方法可以使用，常用的方法一般是基于项目目标的分类方法。风险分解结构（Risk Breakdown Structure, RBS）有助于项目团队在识别风险的过程中发现有可能引起风险的多种原因，不同的 RBS 适用于不同类型的项目。组织可使用预先准备好的分类框架，可以是简易的分类清单或结构化的风险分解结构。RBS 是按风险类别排列的一种层级结构，示例如图 18-3 所示。

6) 风险概率和影响的定义

为了确保风险分析的质量和可信度，项目经理需要对项目环境中特定的风险概率和影响的不同层次进行定义。在规划风险管理过程中，应根据具体项目的需要，裁剪通用的风险概率和影响定义，供后续过程使用。表 18-1 是关于消极影响的例子，可用于评估风险对 4 个项目目标的影响（可对积极影响编制类似的表格）。表 18-1 用相对量表和数字量表（在本例中是非线性的）两种方法来表示影响。

7) 概率和影响矩阵

概率和影响矩阵是把每个风险发生的概率和一旦发生对项目目标的影响映射起来的表格。根据风险可能对项目目标产生的影响，对风险进行优先排序。进行排序的典型方法是使用查询表或概率和影响矩阵。通常由组织来设定概率和影响的组合，并据此设定高、中、低风险级别。

8) 修订的干系人承受力

可在规划风险管理过程中对干系人的承受力进行修订，以适应具体项目的情况。

9) 报告格式

规定将如何记录、分析和沟通风险管理过程的结果，规定风险登记册及其他风险报告的内容和格式。

10) 跟踪

规定将如何记录风险活动，促进当前项目的开展，以及将如何审计风险管理过程。

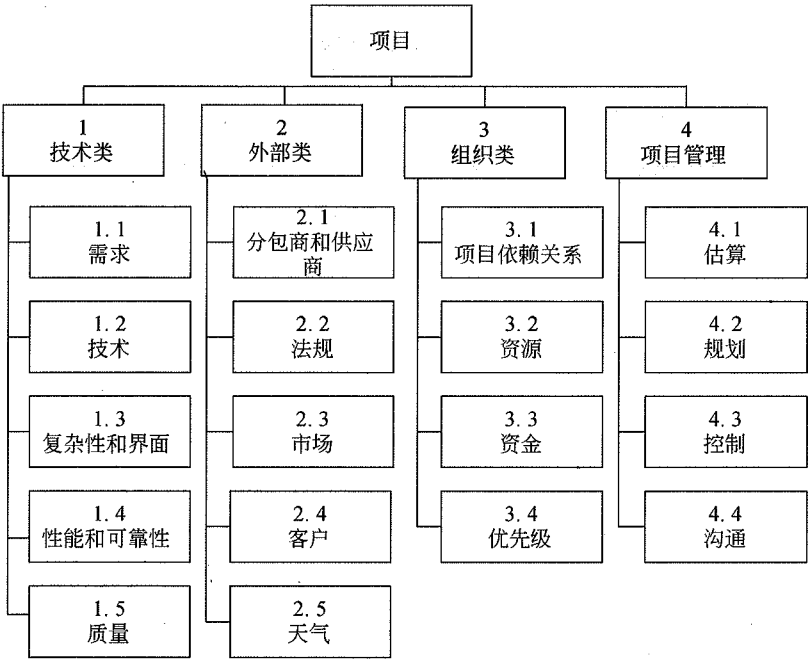


图 18-3 风险分解结构（RBS）示例

表 18-1 风险对 4 个项目目标的影响量表

风险对主要项目目标的影响量表 (仅反映消极影响)					
项目目标	相对量表或数字量表				
	很低 0.05	低 0.10	中等 0.20	高 0.40	很高 0.80
成本	成本增加不显著	成本增加小于 10%	成本增加 10%-20%	成本增加 20%-40%	成本增加大于 40%
进度	进度拖延不显著	进度拖延小于 5%	进度拖延 5%-10%	进度拖延 10%-20%	进度拖延大于 20%
范围	范围减小微不足道	范围的次要方面受到影响	范围的主要方面受到影响	范围缩小到发起人不能接受	项目最终结果没有实际用途
质量	质量下降微不足道	仅有要求极高的部分受到影响	质量下降需要发起人审批	质量降低到发起人不能接受	项目最终结果没有实际用途

本表示范性地定义了风险对 4 个项目目标的影响。在规划风险管理过程中，应根据具体项目的情况及组织的风险临界值对这些定义进行裁剪，可以用类似方法对机会进行影响定义

18.4 识别风险

识别风险是判断哪些风险可能影响项目并记录其特征的过程。本过程的主要作用是，把识别出的风险记录在案，并为项目团队预测未来事件积累知识和技能。图 18-4 描述了本过程的输入、工具与技术和输出。

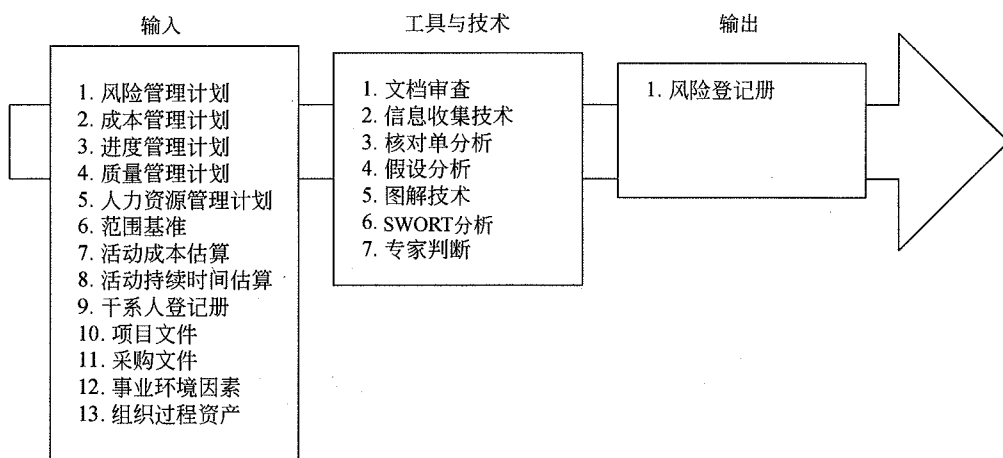


图 18-4 识别风险：输入、工具与技术和输出

风险识别活动的参与者可包括：项目经理、项目团队成员、风险管理团队、客户、项目团队之外的主题专家、最终用户、其他项目经理、干系人和风险管理专家。上述人员往往是风险识别过程的关键参与者，但是在进行风险识别的阶段，项目经理应鼓励全体项目人员参与潜在风险的识别工作，还可以创造并维持团队成员对风险及其应对措施的主人翁感和责任感。项目经理应该推进项目团队之外的干系人提供客观信息，帮助进行风险识别的工作。

我们需要对风险进行准确地识别和判断，作为将来可能采取的行动依据。

风险识别的原则包括：

- (1) 由粗及细，由细及粗。
- (2) 严格界定风险内涵并考虑风险因素之间的相关性。
- (3) 先怀疑，后排除。
- (4) 排除与确认并重。对于肯定不能排除但又不能肯定予以确认的风险按确认考虑。
- (5) 必要时，可作实验论证。

在项目生命周期中，随着项目的进展，新的风险可能产生或为人所知，所以，识别风险是一个反复进行的过程，每个项目进行风险识别的反复频率以及每轮的参与者因具

体情况不同而异。在进行风险识别的不同轮次中，应该采用统一的格式对风险进行描述，确保对每个风险都有明确和清晰的理解，以便有效支持风险分析和应对，文档中对风险的描述应该便于比较项目中的某个风险与其他风险的相对后果。

18.4.1 识别风险的输入

1. 风险管理计划

详见 18.3 节。风险管理计划为识别风险过程提供一些关键要素，包括角色和职责分配、已列入预算和进度计划的风险管理活动，以及可能以风险分解结构的形式呈现的风险类别。

2. 成本管理计划

成本管理计划中规定的工作流程和控制方法有助于在整个项目内识别风险。

3. 进度管理计划

进度管理计划有助于了解可能受风险（已知的和未知的）影响的项目时间目标及预期。

4. 质量管理计划

质量管理计划中规定的质量测量和度量基准，可用于识别风险。

5. 人力资源管理计划

人力资源管理计划为如何定义、配备、管理和最终遣散项目人力资源提供指南。其中也包括角色与职责、项目组织图和人员配备管理计划，它们是识别风险过程的重要输入。

6. 范围基准

项目范围说明书中包括项目的假设条件，应该把项目假设条件中的不确定性作为项目风险的潜在原因加以评估。

WBS 是识别风险过程的关键输入，因为它方便人们同时从微观和宏观两个层面认识潜在风险。可以在总体、控制账户和工作包层级上识别并跟踪风险。

7. 活动成本估算

对活动成本估算进行审查，有利于识别风险。活动成本估算是完成进度活动可能需要成本的量化评估，最好用一个区间来表示，区间的宽度代表着风险的程度。通过审查，可以预知估算的成本是否足以完成某项活动（是否给项目带来风险）。

8. 活动持续时间估算

对活动持续时间估算进行审查，有利于识别与活动或整个项目的应急储备时间有关的风险。类似地，估算区间的宽度代表着风险的相对程度。

9. 干系人登记册

可以利用干系人的信息确保关键干系人，特别是发起人和客户，能以访谈或其他方式参与识别风险过程，为识别风险过程提供各种输入。

10. 项目文件

项目文件能为项目团队更好地识别风险提供与决策有关的信息。项目文件有助于跨团队沟通和干系人之间的沟通。项目文件包括（但不限于）：

- （1）项目章程；
- （2）项目进度计划；
- （3）进度网络图；
- （4）问题日志；
- （5）质量核对单；
- （6）对识别风险有用的其他信息。

11. 采购文件

如果项目需要采购外部资源，采购文件就成为识别风险过程的重要输入。采购文件的复杂程度和详细程度应与计划采购的价值及采购中的风险相匹配。

12. 事业环境因素

能够影响识别风险过程的事业环境因素包括（但不限于）：

- （1）公开发布的信息，包括商业数据库；
- （2）学术研究资料；
- （3）公开发布的核对单，标杆对照资料；
- （4）行业研究资料；
- （5）风险态度。

13. 组织过程资产

能够影响识别风险过程的组织过程资产包括（但不限于）：

- （1）项目文档，包括实际数据；
- （2）组织和项目的过程控制资料；
- （3）风险描述的格式或模板；
- （4）经验教训。

18.4.2 识别风险的工具与技术

1. 文档审查

对项目文档（包括各种计划、假设条件、以往的项目文档、协议和其他信息）进行结构化审查。项目计划的质量，以及这些计划与项目需求和假设之间的匹配程度，都可能是项目的风险指示器。

2. 信息收集技术

可用于风险识别的信息收集技术如下。

1) 头脑风暴

头脑风暴的目的是获得一份综合的项目风险清单。通常由项目团队开展头脑风暴，

团队以外的多学科专家也经常参与其中。在主持人的引导下，参加者提出各种关于项目风险的主意。头脑风暴可采用畅所欲言的传统自由模式，也可采用结构化的集体访谈方式。可用风险类别（如风险分解结构中的）作为基础框架，然后依风险类别进行识别和分类，并进一步阐明风险的定义。

2) 德尔菲技术

德尔菲技术是组织专家达成一致意见的一种方法。项目风险专家匿名参与其中。组织者使用调查问卷就重要的项目风险征询意见，然后对专家的答卷进行归纳，并把结果反馈给专家做进一步评论。这个过程反复几轮后，就可能达成一致意见。德尔菲技术有助于减轻数据的偏倚，防止任何个人对结果产生不恰当的影响。

3) 访谈

访谈有经验的项目参与者、干系人或相关主题专家，有助于识别风险。

4) 根本原因分析

根本原因分析是发现问题、找到其深层原因并制定预防措施的一种特定技术。

3. 核对单分析

可以根据以往类似项目和其他来源的历史信息与知识编制风险识别核对单。也可用风险分解结构的底层作为风险核对单。核对单简单易用但无法穷尽所有事项。在使用中，项目经理应该注意不要用核对单取代必要的风险识别努力，团队应该注意考察未在核对单中列出的事项，对核对单要随时调整，以便增减相关条目。在项目收尾过程中，应对核对单进行审查，并根据新的经验教训改进核对单，供未来项目使用。

4. 假设分析

每个项目及其计划都是基于一套假想、设想或假设而构建的。假设分析是检验假设条件在项目中的有效性，并识别因其中的不准确、不稳定、不一致或不完整而导致的项目风险。

5. 图解技术

风险图解技术可包括：

- (1) 因果图，又称石川图或鱼骨图，用于识别风险的起因。
- (2) 系统或过程流程图，显示系统各要素之间的相互联系及因果传导机制。
- (3) 影响图，用图形方式表示变量与结果之间的因果关系、事件时间顺序及其他关系。如图 18-5 所示。

6. SWOT 分析

这种技术从项目的每个优势（Strength）、劣势（Weakness）、机会（Opportunity）和威胁（Threat）出发，对项目进行考察，把产生于内部的风险都包括在内，从而更全面地考虑风险。首先，从项目、组织或一般业务范围的角度识别组织的优势和劣势。然后，通过 SWOT 分析再识别出由组织优势带来的各种项目机会，以及由组织劣势引发的各种

威胁。这一分析也可用于考察组织优势能够抵消威胁的程度，以及机会可以克服劣势的程度。

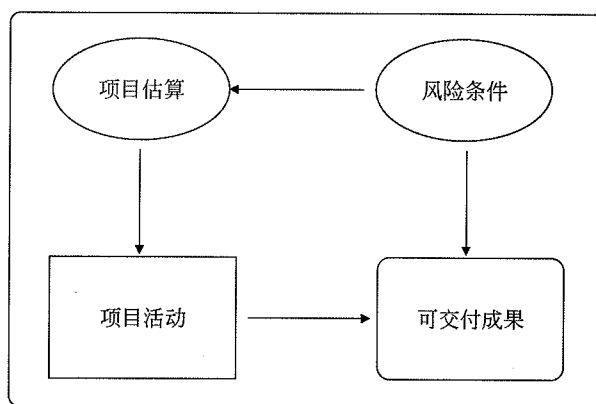


图 18-5 影响图

7. 专家判断

拥有类似项目或业务领域经验的专家，可以直接识别风险。项目经理应该选择相关专家，邀请他们根据以往经验和专业知识客观地指出可能的风险。

18.4.3 识别风险的输出

1. 风险登记册

识别风险过程的主要输出就是风险登记册中的最初内容。风险登记册还会记录风险分析和风险应对规划的结果，随着其他风险管理过程的实施，风险登记册中还将包括这些过程的输出，也就导致风险登记册中信息种类和数量的逐渐增加。风险登记册的编制始于识别风险过程，在项目实施过程中供其他风险管理过程和项目管理过程使用。最初的风险登记册包括如下信息。

1) 已识别风险清单

对已识别风险进行尽可能详细的描述。可采用结构化的风险描述语句对风险进行描述。例如，某事件可能发生，从而造成什么影响。或者如果存在某个原因，某事件就可能发生，从而导致什么影响。在罗列出已识别风险之后，这些风险的根本原因可能更加明显。风险的根本原因就是造成一个或多个已识别风险的基本条件或事件，应记录在案，用于支持本项目和其他项目以后的风险识别工作。

2) 潜在应对措施清单

在识别风险过程中，有时可以识别出风险的潜在应对措施。这些应对措施（如果已经识别出）应该作为规划风险应对过程的输入。

18.5 实施定性风险分析

实施定性风险分析是评估并综合分析风险的概率和影响，对风险进行优先排序，从而为后续分析或行动提供基础的过程。本过程的主要作用是，使项目经理能够降低项目的不确定性级别，并重点关注高优先级的风险。图 18-6 描述了本过程的输入、工具与技术和输出。

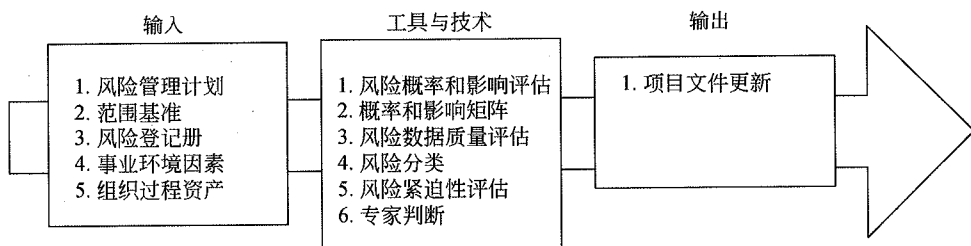


图 18-6 实施定性风险分析：输入、工具与技术和输出

实施定性风险分析根据风险发生的概率或可能性、风险发生后对项目目标的相应影响及其他因素（如应对时间要求，与项目成本、进度、范围和质量等制约因素相关的组织风险承受力），来评估已识别风险的优先级。这类评估会受项目团队和其他干系人的风险态度的影响，为了实现有效评估，就需要项目经理清晰地识别和管理定性风险分析过程的关键参与者的风险处理方式。如果他们的风险处理方式会导致风险评估中的偏颇，项目经理则应该注意对偏颇进行分析与纠正。

建立概率和影响层级的定义，有助于减少偏见的影响。风险行动的时间紧迫性可能会放大风险的重要性。对项目风险相关信息的质量进行评估，也有助于澄清关于风险重要性的评估结果。

实施定性风险分析通常可以快速且经济有效地为制订风险应对措施建立优先级，可以为实施定量风险分析（如果需要的话）奠定基础。需要根据项目风险管理计划的规定，在整个项目生命周期中定期开展定性风险分析过程。本过程完成后，可进入定量风险分析过程或直接进入制订风险应对措施的过程。

18.5.1 实施定性风险分析的输入

1. 风险管理计划

详见 18.3 节。风险管理计划中用于定性风险分析过程的主要部分包括风险管理的角色和职责、风险管理的预算和进度活动、风险类别、概率和影响的定义、概率和影响矩阵及修订的干系人风险承受力。在规划风险管理过程中通常已经将这些内容裁剪至适合

某个具体项目。如果还没有这些内容，则可以在定性风险分析过程中加以开发。

2. 范围基准

常规或反复性项目的风险往往比较容易理解，而采用创新或最新技术且极其复杂的项目，不确定性往往要大得多。可通过查阅范围基准来评估项目情况。

3. 风险登记册

详见18.4节。风险登记册中包含了评估风险和划分风险优先级所需的信息。

4. 事业环境因素

可以从事业环境因素中了解与风险评估有关的背景信息，例如：

- (1) 风险专家对类似项目的行业研究。
- (2) 可以从行业或专有渠道获得的风险数据库。

5. 组织过程资产

能够影响定性风险分析过程的组织过程资产，包括以往已完成的类似项目的信息。

18.5.2 实施定性风险分析的工具与技术

1. 风险概率和影响评估

风险概率评估旨在调查每个具体风险发生的可能性。风险影响评估旨在调查风险对项目目标（如进度、成本、质量或性能）的潜在影响，既包括威胁所造成的消极影响，也包括机会所产生的积极影响。

项目经理应该对已识别的每个风险都要进行概率和影响评估，可以选择熟悉相应风险类别的人员，以访谈或会议的形式进行风险评估。在进行项目风险评估时，应该包括项目团队成员和项目外部经验丰富的人员。

通过访谈或会议方式评估每个风险的概率级别及其对每个目标的影响，还应记录相应的说明性细节。例如，确定风险级别所依据的假设条件。根据风险管理计划中的定义，对风险概率和影响进行评级，具有低概率和影响的风险，将列入风险登记册中的观察清单，供将来监测。

2. 概率和影响矩阵

项目经理应该在基于风险评级结果上，对风险进行优先级排序，以便进一步开展定量分析和制订风险应对措施。通过对风险概率和影响的评估而确定风险评级。通常用查询表或概率和影响矩阵来评估每个风险的重要性和所需的关注优先级。根据概率和影响的各种组合，概率和影响矩阵把风险划分为低、中、高风险。描述风险级别的具体术语和数值取决于组织的偏好。

根据风险发生的概率及发生后对目标的影响程度，对每个风险进行评级。组织应该规定怎样的概率和影响组合是高风险、中等风险和低风险。在黑白矩阵里，用不同的灰度表示不同的风险级别。如图18-7所示，深灰色（数值最大）区域代表高风险，中度灰色（数值最小）区域代表低风险，而浅灰色（数值介于最大和最小之间）区域代表中等

风险。通常，在项目开始之前，组织就要制定风险评级规则，并将其纳入组织过程资产。在规划风险管理过程中，应该根据具体项目的实际，对风险评级规则进行裁剪。

概率和影响矩阵										
概率	威胁					机会				
0.90	0.05	0.09	0.18	0.36	0.72	0.72	0.36	0.18	0.09	0.05
0.70	0.04	0.07	0.14	0.28	0.56	0.56	0.28	0.14	0.07	0.04
0.50	0.03	0.05	0.10	0.20	0.40	0.40	0.20	0.10	0.05	0.03
0.30	0.02	0.03	0.06	0.12	0.24	0.24	0.12	0.06	0.03	0.02
0.10	0.01	0.01	0.02	0.04	0.08	0.08	0.04	0.02	0.01	0.01
	0.05 非常低	0.10 低	0.20 中等	0.40 高	0.80 非常高	0.80 非常高	0.40 高	0.20 中等	0.10 低	0.05 非常低

对目标（如成本、时间、范围或质量）的影响（数字量表）

按发生概率及一旦发生所造成的影响，对每个风险进行评级。在矩阵中显示组织对低风险、中等风险与高风险所规定的临界值。根据这些临界值，把每个风险分别归入高风险、中等风险或低风险。

图 18-7 概率和影响矩阵

注：图 18-7 中，深色和中度灰色，应该对比明显！

如图 18-7 所示，组织可分别针对每个目标（如成本、时间和范围）评定风险等级。另外应该综合对项目各个目标的影响，用相关方法为每个风险确定一个对项目总体的、综合的等级。最后，可以在同一矩阵中，分别列出机会和威胁的影响水平定义，同时显示机会和威胁。

风险值=风险发生的概率*风险发生后的后果

风险值有助于指导风险应对。如果风险发生会对项目目标产生消极影响（威胁）并且处于矩阵高风险（深灰色）区域，就可能需要采取优先措施和激进的应对策略。而处于低风险（中度灰色）区域的威胁，可能只需要作为观察对象列入风险登记册，或为之增加应急储备，而不必采取主动管理措施。同样，处于高风险（深灰色）区域的机会，可能是最易实现且能够带来最大利益的，故应该首先抓住。对于低风险（中度灰色）区域的机会，则应加以监督。

3. 风险数据质量评估

风险数据质量评估是评估风险数据对风险管理的有用程度的一种技术，用来考察人们对风险的理解程度，以及考察风险数据的准确性、质量、可靠性和完整性。

风险数据的质量，直接影响定性分析的结果。使用低质量的风险数据，可能导致定性风险分析起不到应有的作用。如果数据质量无法接受，就可能需要收集更好的数据。收集相关风险信息经常比较困难，要消耗比原计划更多的时间和资源。图 18-7 示例中的

数值具有代表性。通常，随着对组织风险态度的确定，就能确定量表中的数值。

4. 风险分类

可以按照风险来源（如使用风险分解结构）、受影响的项目工作（如使用工作分解结构）或其他有效分类标准（如项目阶段）对项目风险进行分类，以确定受不确定性影响最大的项目区域。也可以根据风险共同的根本原因进行分类，利用风险分类计数有助于制定有效的风险应对措施而确定工作包、活动、项目阶段，甚至项目中的角色。

5. 风险紧迫性评估

可以把近期需要应对的风险确定为更紧迫的风险。风险的可监测性、风险应对的时间要求、风险征兆和预警信号，以及风险等级等，都是确定风险优先级应考虑指标。在某些定性分析中，可以综合考虑风险的紧迫性及从概率和影响矩阵中得到的风险等级，从而得到最终的风险严重性级别。

6. 专家判断

为了确定风险在矩阵中的位置，组织需要使用专家判断来评估每个风险的概率和影响。专家通常是那些具有新近类似项目经验的人。专家判断经常可通过风险研讨会或访谈来获取。应该注意消除某个专家的偏见。

18.5.3 实施定性风险分析的输出

可能需要更新的项目文件包括（但不限于）：

（1）风险登记册。随着定性风险评估产生出新信息，而更新风险登记册。更新的内容包括对每个风险的概率和影响评估、风险评级和分值、风险紧迫性或风险分类，以及低概率风险的观察清单或需要进一步分析的风险。

（2）假设条件日志。随着定性风险评估产生出新信息，假设条件可能发生变化。需要根据这些新信息来调整假设条件日志。假设条件可包含在项目范围说明书中，也可记录在独立的假设条件日志中。

18.6 实施定量风险分析

实施定量风险分析是就已识别风险对项目整体目标的影响进行定量分析的过程。本过程的主要作用是，产生量化风险信息，来支持决策制定，降低项目的不确定性。图18-8描述了本过程的输入、工具与技术和输出。

实施定量风险分析的对象是在定性风险分析过程中被确定为对项目的竞争性需求存在重大潜在影响的风险。实施定量风险分析过程就是分析这些风险对项目目标的影响，主要用来评估所有风险对项目的总体影响。在进行定量分析时，也可以对单个风险分配优先级数值。

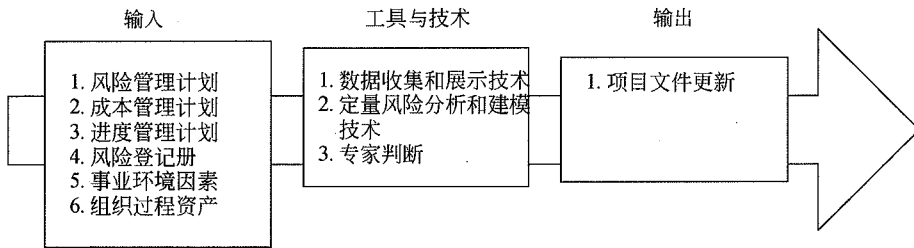


图 18-8 实施定量风险分析：输入、工具与技术和输出

通常情况下，实施定量风险分析一般在实施定性风险分析过程之后开展，在没有足够的数建立模型的时候，定量风险分析可能无法实施。项目经理应该运用专家判断来确定定量风险分析的必要性和有效性。在特定的项目中，采用哪些方法进行风险分析，取决于可用的时间和预算，以及对风险及其后果进行定性或定量描述的需要。作为控制风险过程的一部分，应反复开展实施定量风险分析过程，以确定整体项目风险的降低程度是否令人满意。可以根据风险的发展趋势适当增减风险管理活动。

18.6.1 实施定量风险分析的输入

1. 风险管理计划

详见 18.3 节。风险管理计划为定量风险分析提供指南、方法和工具。

2. 成本管理计划

成本管理计划为建立和管理风险储备提供指南。

3. 进度管理计划

进度管理计划为建立和管理风险储备提供指南。

4. 风险登记册

详见 18.4 节。风险登记册为实施定量风险分析提供基础。

5. 事业环境因素

可以从事业环境因素中了解与风险分析有关的背景信息，例如：

- (1) 风险专家对类似项目的行业研究；
- (2) 可以从行业或专有渠道获得的风险数据库。

6. 组织过程资产

能够影响实施定量风险分析过程的组织过程资产包括以往已完成的类似项目的信息。

18.6.2 实施定量风险分析的工具与技术

1. 数据收集和展示技术

1) 访谈

访谈技术利用经验和历史数据，对风险概率及其对项目目标的影响进行量化分析。

所需的信息取决于所用的概率分布类型。例如，有些常用分布要求收集最乐观、最悲观与最可能情况的信息。图 18-9 是用三点估算法估算成本的一个例子，在这个估算成本的例子里“低”表示最乐观，“高”表示最悲观。关于三点估算法的更多信息，见估算活动持续时间和估算成本。在风险访谈中，应该记录风险区间的合理性及其所依据的假设条件，以便洞察风险分析的可靠性和可信度。

项目成本估算的区间（单位：百万元）			
WBS 要素	低	最可能	高
设计	4	6	10
建造	16	20	35
试验	11	15	23
整个项目	31	41	68

对有关系人进行访谈，有助于确定每个WBS要素的三大估计（用于三角分布、贝塔分布或其他分布）。在本例中，以等于或小于4100万美元（最可能估计）完成项目的可能性很低，如图模拟结果所示（成本风险模拟结果）。

图 18-9 险访谈所得到的成本估算区间

2) 概率分布

在建模和模拟中广泛使用的连续概率分布，代表着数值的不确定性，如进度活动的持续时间和项目组成部分成本的不确定性。不连续分布用于表示不确定性事件，如测试结果或决策树的某种可能情景等。图 18-10 显示了广为使用的两种连续概率分布。这些分布的形状与量化风险分析中得出的典型数值相符。如果在具体的最高值和最低值之间，没有哪个数值的可能性比其他数值更高，就可以使用均匀分布，如在早期的概念设计阶段。

2. 定量风险分析和建模技术

常用的技术有面向事件和面向项目的分析方法，包括：

1) 敏感性分析

敏感性分析有助于确定哪些风险对项目具有最大的潜在影响。它有助于理解项目目标的变化与各种不确定因素的变化之间存在怎样的关联。把所有其他不确定因素固定在基准值上，考察每个因素的变化会对目标产生多大程度的影响。敏感性分析的典型表现形式是龙卷风图（如图 18-11 所示），用于比较很不确定的变量与相对稳定的变量之间的相对重要性和相对影响。对于那些定量分析显示可能收益大于消极影响的特定风险，龙

卷风图也有助于分析冒险情景。龙卷风图是在敏感性分析中用来比较不同变量的相对重要性的一种特殊形式的条形图。在龙卷风图中，Y轴代表处于基准值的各种不确定因素，X轴代表不确定因素与所研究的输出之间的相关性。图中每种不确定因素各有一根水平条形，从基准值开始向两边延伸。这些条形按延伸长度递减垂直排列。

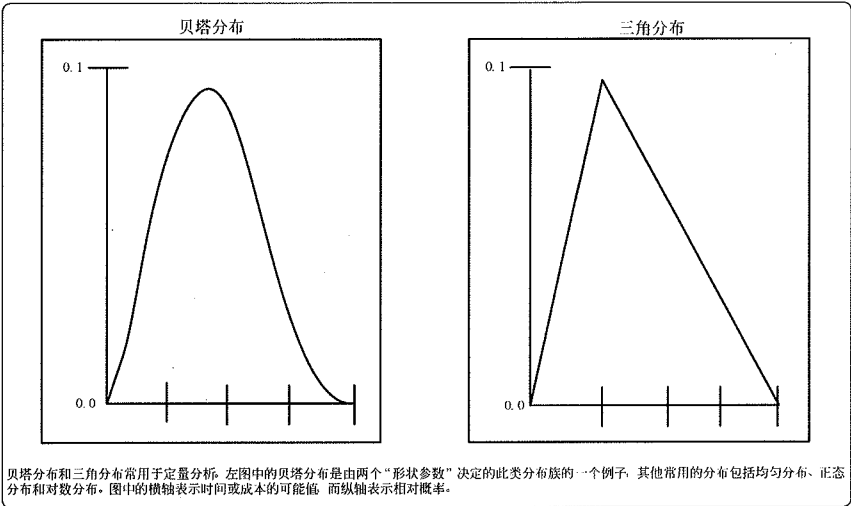


图 18-10 常用概率分布示例

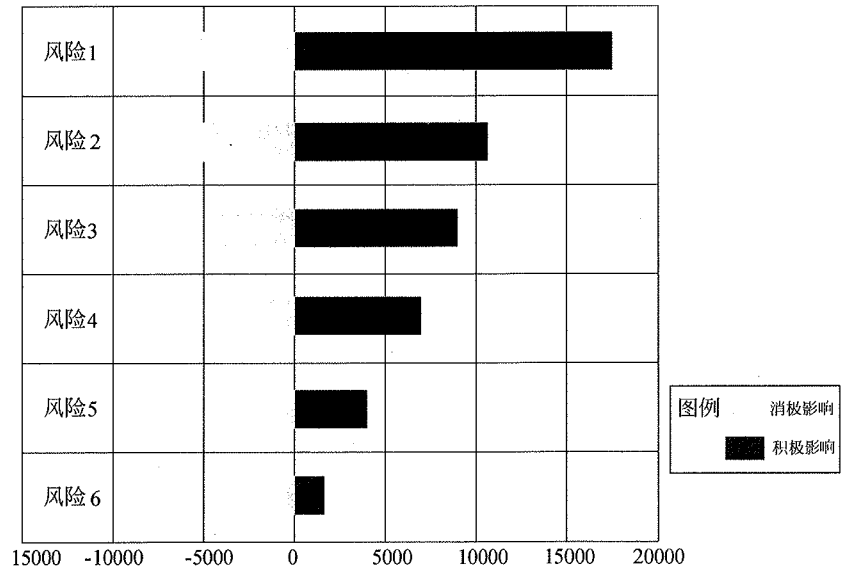


图 18-11 龙卷风图示例

2) 预期货币价值分析

预期货币价值 (EMV) 分析是当某些情况在未来可能发生或不发生时, 计算平均结果的一种统计方法 (不确定性下的分析)。机会的 EMV 通常表示为正值, 而威胁的 EMV 则表示为负值。EMV 是建立在风险中立的假设之上的, 既不避险, 也不冒险。把每个可能结果的数值与其发生的概率相乘, 再把所有乘积相加, 就可以计算出项目的 EMV。这种技术经常在决策树分析中使用 (如图 18-12 所示)。

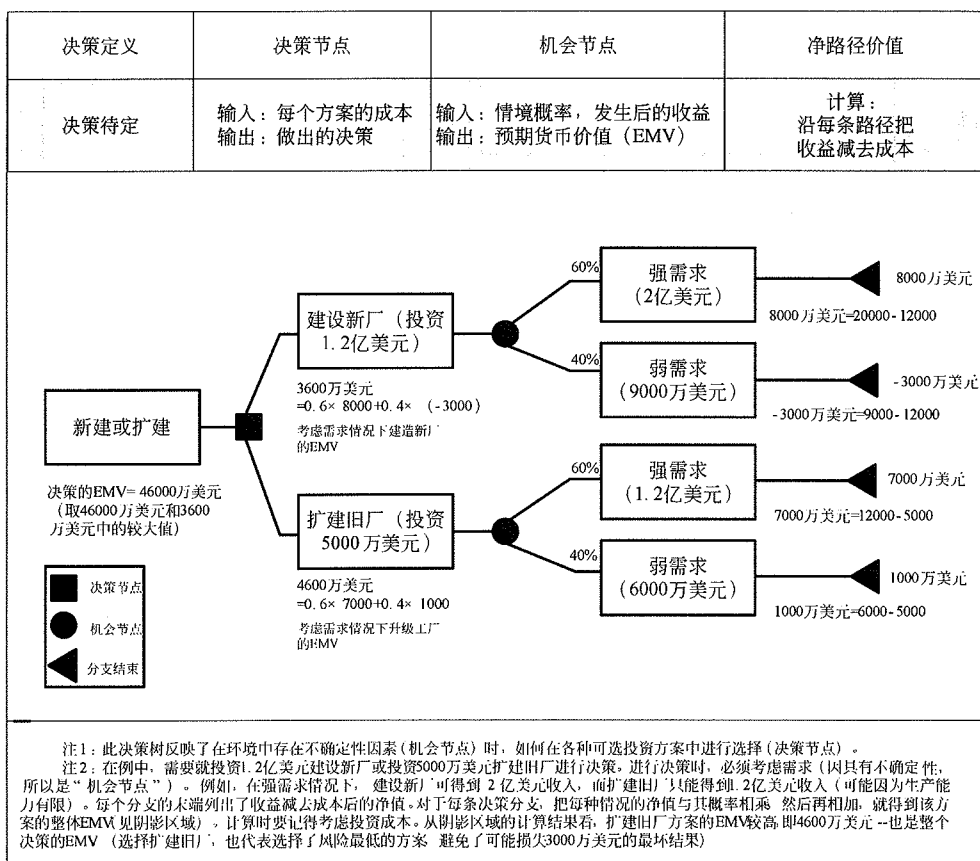


图 18-12 决策树分析示例

3) 建模和模拟

项目模拟旨在使用一个模型, 计算项目各细节方面的不确定性对项目目标的潜在影响。模拟通常采用蒙特卡洛技术。在模拟中, 要利用项目模型进行多次 (反复) 计算。每次计算时, 都从这些变量的概率分布中随机抽取数值 (如成本估算或活动持续时间) 作为输入。通过多次计算, 得出一个概率分布直方图 (如总成本或完成日期)。对于成本风险分析, 需要使用成本估算进行模拟。对于进度风险分析, 需要使用进度网络图和持

续时间估算进行模拟。图 18-13 是用三元模型和风险区间得出的成本风险模拟结果，它表明了实现各个特定成本目标的可能性。对其他项目目标也能画出类似曲线。

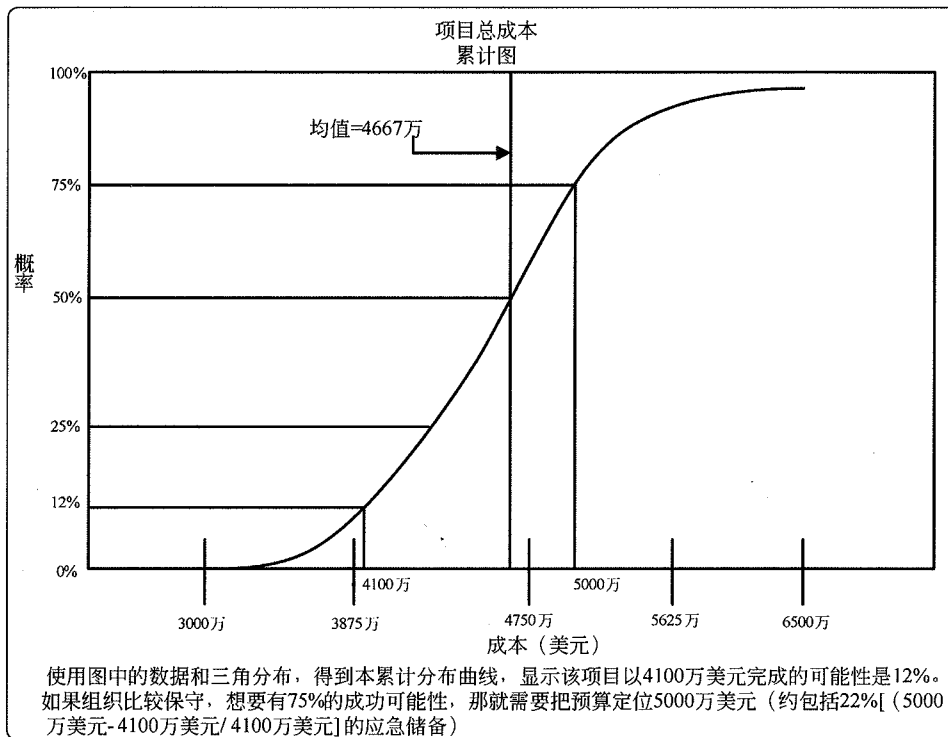


图 18-13 成本风险模拟结果

3. 专家判断

专家判断（最好来自具有近期相关经验的专家）用于识别风险对成本和进度的潜在影响，估算概率及定义各种分析工具所需的输入，如概率分布。

专家判断还可在数据解释中发挥作用。专家应该能够识别各种分析工具的劣势与优势。根据组织的能力和文化，专家可以决定某个特定工具应该或不应该在何时使用。

18.6.3 实施定量风险分析的输出

项目文件要随着定量风险分析产生的信息而更新。例如，风险登记册更新包括：

1. 项目的概率分析

对项目可能的进度与成本结果进行估算，列出可能的完工日期和完工成本及其相应的置信水平。分析的结果通常表现为累积频率分布。可以综合考虑分析的结果与干系人的风险承受力，来量化所需的成本和时间应急储备。应急储备旨在把不能实现成本和时

间目标的风险降低到组织可接受的水平。

2. 实现成本和时间目标的概率

当项目面临风险时，可根据定量风险分析的结果来估算在现行计划下实现项目目标的概率。

3. 量化风险优先级清单

此风险清单中包括对项目造成最大威胁或提供最大机会的风险。它们是对成本应急储备影响最大的风险，以及最可能影响关键路径的风险。在某些情况下，可使用敏感性分析中生成的龙卷风图来评估这些风险。

4. 定量风险分析结果的趋势

随着分析的反复进行，风险可能呈现某种明显的趋势。可以从这种趋势中得到某些结论，并据此调整风险应对措施。从实施定量风险分析过程中知悉的新信息，应该成为组织中项目进度、成本、质量和性能历史信息的组成部分。这些新信息可能以定量风险分析报告的形式呈现。该报告可以独立于风险登记册，也可以与风险登记册合并在一起。

18.7 规划风险应对

规划风险应对是针对项目目标，制订提高机会、降低威胁的方案和措施的过程。本过程也叫“制订风险应对措施，或者叫制订风险应对计划”，其主要作用是，根据风险的优先级来制定应对措施，并把风险应对所需的资源和活动加进项目的预算、进度计划和项目管理计划中。图 18-14 描述了本过程的输入、工具与技术和输出。

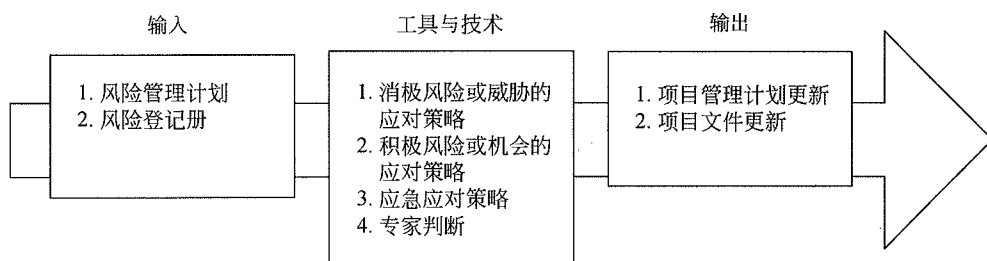


图 18-14 规划风险应对：输入、工具与技术和成果

在实施定量风险分析（如已使用）之后开展规划风险应对过程。制定风险应对措施需要理解风险处理机制，这是一种可据此分析风险应对计划是否正在发挥应有作用的机制。其中包括确定和分配某个人（风险应对责任人）来实施已获同意和资金支持的风险应对措施。风险应对措施必须与风险的重要性相匹配，能经济有效地应对挑战。在当前项目背景下现实可行，能获得全体相关方的同意，并由一名责任人具体负责。经常需要从几个备选方案中选择最佳的风险应对措施。

当风险出现时，不同的人会持有不同的态度，如：

1. 厌恶型

对风险的发生持否定态度。当风险出现时，往往采取消极、回避、甚至面对事实也采取拒不承认的态度，往往采取消极行动或者是敷衍。

2. 促进型

面对风险的发生持积极态度。当风险出现时，往往采取积极、争取、促进风险进一步发挥作用的态度，往往采取积极行动或者直接参与。

3. 中间型

面对风险的发生持中间态度。当风险未发生时，不进行促进发生等活动，但是随时保持警戒状态。当风险发生时，积极面对，不回避不逃避，采用有效的行动对风险本身和风险有可能引起的后果进行管理和控制。

在进行项目风险应对管理时，在可能的情况下，应根据风险的种类、特点、影响，面对风险的不同态度等方面确定不同的风险应对策略。

规划风险应对过程介绍常用的风险应对措施规划方法。由于风险包括能影响项目成功的威胁和机会，本节将分别讨论威胁和机会的应对措施。

18.7.1 规划风险应对的输入

1. 风险管理计划

风险管理计划的重要内容包括角色和职责、风险分析定义、审查时间安排（以及经审查而删去风险的时间安排）以及关于低、中、高风险的风险临界值。风险临界值有助于识别需要特定应对措施的风险。

2. 风险登记册

风险登记册中包含已识别的风险、风险的根本原因、潜在应对措施清单、风险责任人、征兆和预警信号、项目风险的相对评级或优先级清单、近期需要应对的风险、需要进一步分析和应对的风险清单、定性分析结果的趋势，以及低优先级风险的观察清单。

18.7.2 规划风险应对的工具与技术

有若干种风险应对策略可供使用。应该为每个风险选择最可能有效的策略或策略组合。可利用风险分析工具（如决策树分析）来选择最适当的应对策略。然后，应制定具体行动去实施该策略，包括主要策略和备用策略（如果必要的话）。可以制定弹回计划，以便在所选策略无效或发生已接受的风险时加以实施。还应该对次生风险进行审查。次生风险是实施风险应对措施的直接结果。经常要为时间或成本分配应急储备，并可能需要说明动用应急储备的条件。

1. 消极风险或威胁的应对策略

通常用规避、转移、减轻这三种策略来应对威胁或可能给项目目标带来消极影响的

风险。第四种策略，即接受，既可用于应对消极风险或威胁，也可用于应对积极风险或机会。每种风险应对策略对风险状况都有不同且独特的影响。要根据风险的发生概率和对项目总体目标的影响选择不同的策略。规避和减轻策略通常适用于高影响的严重风险，而转移和接受则更适用于低影响的不太严重威胁。

1) 规避

风险规避是指项目团队采取行动来消除威胁，或保护项目免受风险影响的风险应对策略。通常包括改变项目管理计划，以完全消除威胁。项目经理也可以把项目目标从风险的影响中分离出来，或者改变受到威胁的目标，如延长进度、改变策略或缩小范围等。最极端的规避策略是关闭整个项目。在项目早期出现的某些风险，可以通过澄清需求、获取信息、改善沟通或取得专有技能来加以规避。

2) 转移

风险转移是指项目团队把威胁造成的影响连同应对责任一起转移给第三方的风险应对策略。转移风险是把风险管理责任简单地推给另一方，而并非消除风险。转移并不是把风险推给后续的项目，也不是未经他人知晓或同意就把风险推给他人。采用风险转移策略，几乎总是需要向风险承担者支付风险费用。风险转移策略对处理风险的财务后果最有效。风险转移可采用多种工具，包括（但不限于）保险、履约保函、担保书和保证书等。可以利用合同或协议把某些具体风险转移给另一方。例如，如果买方具备卖方所不具备的某种能力，为谨慎起见，可通过合同规定把部分工作及其风险再转移给买方。在许多情况下，成本补偿合同可把成本风险转移给买方，而总价合同可把风险转移给卖方。

3) 减轻

风险减轻是指项目团队采取行动降低风险发生的概率或造成的影响的风险应对策略。它意味着把不利风险的概率和影响降低到可接受的临界值范围内。提前采取行动来降低风险发生的概率和可能给项目造成的影响，比风险发生后再设法补救会更加有效。减轻措施的例子包括采用不太复杂的流程，进行更多的测试，或者选用更可靠的供应商。它可能需要开发原型，以降低从实验台模型放大到实际工艺或产品过程中的风险。如果无法降低风险概率，也许可以从决定风险严重性的关联点入手，针对风险影响来采取减轻措施。例如，在一个系统中加入冗余部件，可以减轻主部件故障所造成的影响。

4) 接受

风险接受是指项目团队决定接受风险的存在，该策略可以是被动或主动的。

被动接受策略不采取任何措施，只需要记录本策略，而无需任何其他行动，待风险发生时再由项目团队处理。不过，需要定期复查，以确保威胁没有太大的变化。

如果采取主动接受的策略，则要在风险发生前制定应急计划。最常见的主动接受策略是建立应急储备，安排一定的时间、资金或资源来应对风险。

无论被动接受还是主动接受，风险的接受策略在不可能采取其他方法时使用，或者

在其他方法不具经济有效性时使用。该策略表明，项目团队已决定不为处理某风险而变更项目管理计划，或者无法找到任何其他的合理应对策略。

2. 积极风险或机会的应对策略

以下四种策略中，前三种是专为对项目目标有潜在积极影响的风险而设计的。第四种策略，即接受，既可用于应对消极风险或威胁，也可用于应对积极风险或机会。

1) 开拓

如果组织想要确保机会得以实现，就可对具有积极影响的风险采取本策略。本策略旨在消除与某个特定积极风险相关的不确定性，确保机会肯定出现。直接开拓包括把组织中最有能力的资源分配给项目来缩短完成时间，或者采用全新或改进的技术来节约成本，缩短实现项目目标的持续时间。

2) 提高

本策略旨在提高机会的发生概率和积极影响。识别那些会影响积极风险发生的关键因素，并使这些因素最大化，以提高机会发生的概率。提高机会的例子包括为尽早完成活动而增加资源。

3) 分享

分享积极风险是指把应对机会的部分或全部责任分配给最能为项目利益抓住该机会的第三方。分享的例子包括建立风险共担的合作关系和团队，以及为特殊目的成立公司或联营体，以便充分利用机会，使各方都从中受益。

4) 接受

接受机会是指当机会发生时乐于利用，但不主动追求机会。

3. 应急应对策略

可以针对某些特定事件，专门设计一些应对措施。对于有些风险，项目团队可以制定应急应对策略，即只有在某些预定条件发生时才能实施的应对计划。如果确信风险的发生会有充分的预警信号，就应该制定应急应对策略。应该对触发应急策略的事件进行定义和跟踪，例如，未实现阶段性里程碑，或者获得供应商更高层次的重视。采用这一技术制定的风险应对方案，通常称为应急计划或弹回计划，其中包括已识别的、用于启动计划的触发事件。

4. 专家判断

由具有相关知识者为每个具体的、已定义的风险的应对措施做出专家判断。专家判断可以来自具有特定教育、知识、技能、经验或培训背景的任何小组或个人。

18.7.3 规划风险应对的输出

1. 项目管理计划更新

开展本过程可能导致项目管理计划更新。更新的内容包括（但不限于）：

1) 进度管理计划

更新进度管理计划，反映风险应对措施所带来的变更。可能包括与资源负荷和资源平衡相关的容忍度变更或行为变更，以及进度策略更新。

2) 成本管理计划

更新成本管理计划，反映风险应对措施所带来的变更。可能包括与成本会计、跟踪和报告有关的容忍度变更或行为变更，以及预算策略更新和应急储备使用方法更新。

3) 质量管理计划

更新质量管理计划，反映风险应对措施所带来的变更。可能包括与需求、质量保证或质量控制有关的容忍度变更或行为变更，以及需求文件更新。

4) 采购管理计划

更新采购管理计划，反映风险应对措施所带来的策略变更，如自制或外购决策的变化，或者由风险应对措施所带来的合同类型的变化。

5) 人力资源管理计划

更新人力资源管理计划中的人员配备管理计划，反映风险应对措施所带来的项目组织结构变更和资源使用变更。可能包括与人员分配有关的容忍度变更或行为变更，以及资源负荷更新。

6) 范围基准

更新范围基准，反映因应对风险而产生的新工作、工作变更或工作取消。

7) 进度基准

更新进度基准，反映因应对风险而产生的新工作（或取消的工作）。

8) 成本基准

更新成本基准，反映因应对风险而产生的新工作（或取消的工作）。

2. 项目文件更新

在规划风险应对过程中，应该根据需要更新若干项目文件。例如，选择和商定的风险应对措施应该列入风险登记册。风险登记册的详细程度应与风险的优先级和将要采取的应对措施相适应。通常，应该详细说明高风险和中风险，而把低优先级的风险列入观察清单，以便定期监测。风险登记册的更新应该包括（但不限于）：

- (1) 风险责任人及其职责；
- (2) 商定的应对策略；
- (3) 实施所选应对策略所需要的具体行动；
- (4) 风险发生的触发条件、征兆和预警信号；
- (5) 实施所选应对策略所需要的预算和进度活动；
- (6) 应急计划及启动应急计划的触发因素；
- (7) 弹回计划，以便在风险发生并且主要应对措施无效时使用；
- (8) 在采取预定应对措施之后仍然存在的残余风险，以及已经有意接受的风险；
- (9) 实施风险应对措施直接导致的次生风险；

（10）根据项目的定量风险分析及组织的风险临界值，计算出来的应急储备。

18.8 控制风险

控制风险是在整个项目中实施风险应对计划、跟踪已识别风险、监督残余风险、识别新风险，以及评估风险过程有效性的过程。本过程的主要作用是，在整个项目生命周期中提高应对风险的效率，不断优化风险应对措施。图 18-15 描述了本过程的输入、工具与技术和输出。

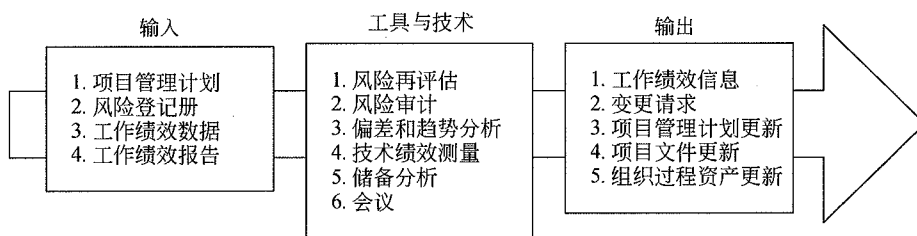


图 18-15 控制风险：输入、工具与技术和输出

应该在项目生命周期中，实施风险登记册中所列的风险应对措施，还应该持续监督项目工作，以便发现新风险、风险变化和过时风险。

控制风险过程需要基于项目执行中生成的绩效数据，采用诸如偏差和趋势分析的各种技术。控制风险过程的其他目的在于确定：

- ① 项目假设条件是否仍然成立；
- ② 某个已评估过的风险是否已发生变化或消失；
- ③ 风险管理政策和程序是否已得到遵守；
- ④ 根据当前的风险评估，是否需要调整成本或进度应急储备。

控制风险会涉及选择替代策略、实施应急或弹回计划、采取纠正措施，以及修订项目管理计划。风险应对责任人应定期向项目经理汇报计划的有效性、未曾预料到的后果，以及为合理应对风险而需要采取的纠正措施。在控制风险过程中，还应更新组织过程资产（如项目经验教训数据库和风险管理模板），以使未来的项目受益。

18.8.1 控制风险的输入

1. 项目管理计划

项目管理计划包括风险管理计划，为风险监控提供指南。

2. 风险登记册

风险登记册中包括已识别的风险、风险责任人、商定的风险应对措施、评估应对计

划有效性的控制行动、风险应对措施、具体的实施行动、风险征兆和预警信号、残余风险和次生风险、低优先级风险观察清单，以及时间和成本应急储备。观察清单包括在风险登记册中，是低优先级风险的清单。

3. 工作绩效数据

与可能受风险影响的工作相关的工作绩效数据包括（但不限于）：

- （1）可交付成果的状态；
- （2）进度进展情况；
- （3）已经发生的成本。

4. 工作绩效报告

工作绩效报告是从绩效测量值中提取信息并进行分析的结果，提供关于项目工作绩效的信息，包括偏差分析结果、挣值数据和预测数据等。这些数据有助于控制与绩效有关的风险。

18.8.2 控制风险的工具与技术

1. 风险再评估

在控制风险中，经常需要识别新风险，对现有风险进行再评估，以及删去已过时的风险。应该定期进行项目风险再评估。反复进行再评估的次数和详细程度，应该根据相对于项目目标的项目进展情况而定。

2. 风险审计

风险审计是检查并记录风险应对措施在处理已识别风险及其根源方面的有效性，以及风险管理过程的有效性。项目经理要确保按项目风险管理计划所规定的频率实施风险审计。既可以在日常的项目审查会中进行风险审计，也可单独召开风险审计会议。在实施审计前，要明确定义审计的格式和目标。

3. 偏差和趋势分析

很多控制过程都会借助偏差分析来比较计划结果与实际结果。为了控制风险，应该利用绩效信息对项目执行的趋势进行审查。可使用挣值分析，以及项目偏差与趋势分析的其他方法，对项目总体绩效进行监控。这些分析的结果可以揭示项目在完成时可能偏离成本和进度目标的程度。与基准计划的偏差可能表明威胁或机会的潜在影响。

4. 技术绩效测量

技术绩效测量是把项目执行期间所取得的技术成果与计划取得的技术成果进行比较。它要求定义关于技术绩效的客观的、量化的测量指标，以便据此比较实际结果与计划要求。这些技术绩效测量指标可包括重量、处理时间、缺陷数量和存储容量等。偏差值（如在某里程碑实现了比计划更多或更少的功能）有助于预测项目范围方面的成功程度。

5. 储备分析

在项目实施过程中，可能发生一些对预算或进度应急储备有积极或消极影响的风险。储备分析是指在项目的任何时间点比较剩余应急储备与剩余风险量，从而确定剩余储备是否仍然合理。

6. 会议

项目风险管理应该是定期状态审查会中的一项议程。该议程所占用的会议时间长短取决于已识别的风险及其优先级和应对难度。越经常开展风险管理，风险管理就会变得越容易。经常讨论风险，可以促使人们识别风险和机会。

18.8.3 控制风险的输出

1. 工作绩效信息

作为控制风险的输出，工作绩效信息提供了沟通和支持项目决策的机制。

2. 变更请求

有时，实施应急计划或权变措施会导致变更请求。变更请求要提交给实施整体变更控制过程审批。变更请求也可包括推荐的纠正措施和预防措施。

1) 推荐的纠正措施

为了使项目工作绩效重新符合项目管理计划而开展的活动，包括应急计划和权变措施。后者是针对以往未曾识别或被动接受的、目前正在发生的风险而采取的、未经事先计划的应对措施。

2) 推荐的预防措施

为确保未来的项目工作绩效符合项目管理计划而开展的活动。

3. 项目管理计划更新

如果经批准的变更请求对风险管理过程有影响，则应修改并重新发布项目管理计划中的相应组成部分，以反映这些经批准的变更。项目管理计划中可能需要更新的内容与规划风险应对过程相同。

4. 项目文件更新

作为控制风险过程的结果，可能需要更新的项目文件包括（但不限于）风险登记册。风险登记册更新包括：

1) 风险再评估、风险审计和定期风险审查的结果

这些结果可能包括新识别的风险，以及对风险概率、影响、优先级、应对计划、责任人和风险登记册其他要素的更新。还可能包括删掉不再存在的风险，并释放相应的储备。

2) 项目风险及其应对的实际结果

这些信息有助于项目经理们横跨整个组织进行风险规划，也有助于他们改进未来项目的风险规划。

5. 组织过程资产更新

在风险管理过程中生成的、可供未来项目借鉴的各种信息应收入组织过程资产中。

可能需要更新的组织过程资产包括（但不限于）：

- （1）风险管理计划的模板，包括概率和影响矩阵、风险登记册；
- （2）风险分解结构；
- （3）从项目风险管理活动中得到的经验教训。

应该在需要时和项目收尾时，对上述文件进行更新。风险登记册和风险管理计划模板的最终版本、核对单和风险分解结构都应该包括在组织过程资产中。

第 19 章 项目收尾管理

项目收尾管理是系统集成项目管理中一个特殊的阶段，从字面上很容易理解收尾管理的工作内容，但在实际操作中却存在较多的困难。尤其是软件类型的系统集成项目往往容易受到业务、技术、人员等多方面因素的影响，导致项目在最终完成时与项目前期所规划的内容存在较大的差异。另外，系统集成项目所交付的最终产品缺乏标准型，因而对其衡量和评价也存在一定的困难。此外，项目收尾还因为涉及到不同角色的部门和人员，而这些部门和人员对于系统集成项目关注的目标又各有差异。在实际工作中，广义的系统集成项目收尾管理工作通常包含了四类典型的工作，即项目验收工作、项目总结工作、系统维护工作以及项目后评价工作，此外项目团队成员的后续工作也应在收尾管理时妥善安排；狭义的系统集成项目收尾管理工作则主要指项目验收工作。收尾管理属于项目整体管理中项目结束阶段的主要过程（参见第 6 章）。

19.1 项目验收

项目验收是项目收尾管理中的首要环节，只有完成项目验收工作后，才能进入后续的项目总结、系统维护以及项目后评价等工作阶段。

项目的正式验收包括验收项目产品、文档及已经完成的交付成果。对系统集成项目进行验收时需要根据项目前期所签署的合同内容以及对应的技术工作内容，如果在项目执行过程中发生了合同变更，还应将变更内容也作为项目验收的评价依据。对于软件类型的系统集成项目而言，除了依据项目前期的合同内容，通常还需要将甲乙双方签署或认可的软件需求规格说明书作为验收依据。在执行软件项目验收测试时，验收测试用例应该覆盖软件需求规格说明书中所有的功能性需求和非功能性需求。

项目验收工作需要完成正式的验收报告，验收报告包含了验收的主要内容以及相应的验收结论，参与验收的各方应该对验收结论进行签字确认，对验收结果承担相应的责任。对于系统集成项目，一般需要执行正式的验收测试工作。验收测试工作可以由业主和承建单位共同进行，也可以由第三方公司进行，但无论哪种方式都需要以项目前期所签署的合同以及相关的支持附件作为依据进行验收测试，而不得随意变更验收测试的依据。对于那些发生了重大变更的系统集成项目，则应以变更后的合同及其附件作为验收测试的主要依据。

具体而言，系统集成项目在验收阶段主要包含以下四方面的工作内容，分别是验收测试、系统试运行、系统文档验收以及项目终验。

1. 验收测试

验收测试是对信息系统进行全面的测试，依照双方合同约定的系统环境，以确保系统的功能和技术设计满足建设方的功能需求和非功能需求，并能正常运行。验收测试阶段应包括编写验收测试用例，建立验收测试环境，全面执行验收测试，出具验收测试报告以及验收测试报告的签署。

2. 系统试运行

信息系统通过验收测试环节以后，可以开通系统试运行。系统试运行期间主要包括数据迁移、日常维护以及缺陷跟踪和修复等方面的工作内容。为了检验系统的试运行情况，客户可将部分数据或配置信息加载到信息系统上进行正常操作。在试运行期间，甲乙双方可以进一步确定具体的工作内容并完成相应的交接工作。对于在试运行期间系统发生的问题，根据其性质判断是否是系统缺陷，如果是系统缺陷，应该及时更正系统的功能；如果不是系统自身缺陷，而是额外的信息系统新需求，此时可以遵循项目变更流程进行变更，也可以将其暂时搁置，作为后续升级项目工作内容的一部分。

3. 系统文档验收

系统经过验收测试后，系统的文档应当逐步、全面地移交给客户。客户也可按照合同或者项目工作说明书的规定，对所交付的文档加以检查和评价；对不清晰的地方可以提出修改要求。在最终交付系统前，系统的所有文档都应当验收合格并经双方签字认可。

对于系统集成项目，所涉及的文档应该包括如下部分：

- (1) 系统集成项目介绍；
- (2) 系统集成项目最终报告；
- (3) 信息系统说明手册；
- (4) 信息系统维护手册；
- (5) 软硬件产品说明书、质量保证书等。

4. 项目终验

在系统经过试运行以后的约定时间，例如三个月或者六个月，双方可以启动项目的最终验收工作。通常情况下，大型项目都分为试运行和最终验收两个步骤。对于一般项目而言，可以将系统测试和最终验收合并进行，但需要对最终验收的过程加以确认。

最终验收报告就是业主方认可承建方项目工作的最主要文件之一，这是确认项目工作结束的重要标志。对于信息系统而言，最终验收标志着项目的结束和售后服务的开始。

最终验收的工作包括双方对验收测试文件的认可和接受、双方对系统试运行期间的工作状况的认可和接受、双方对系统文档的认可和接受、双方对结束项目工作的认可和接受。

项目最终验收合格后，应该由双方的项目组撰写验收报告提请双方工作主管认可。这标志着项目组开发工作的结束和项目后续活动的开始。

19.2 项目总结

项目总结属于项目收尾的管理收尾。而管理收尾有时又被称为行政收尾，就是检查项目团队成员及相关干系人是否按规定履行了所有职责。实施行政收尾过程还包括收集项目记录、分析项目成败、收集应吸取的教训，以及将项目信息存档供本组织将来使用等活动。

1. 项目总结的意义

项目总结的主要意义如下。

- (1) 了解项目全过程的工作情况及相关的团队或成员的绩效状况。
- (2) 了解出现的问题并进行改进措施总结。
- (3) 了解项目全过程中出现的值得吸取的经验并进行总结。
- (4) 对总结后的文档进行讨论，通过后即存入公司的知识库，从而纳入企业的过程资产。

2. 项目总结会的准备工作

1) 收集整理项目过程文档和经验教训

这需要全体项目人员共同进行，而非项目经理一人的工作。项目经理可将此项工作列入项目的收尾工作中，作为参与项目人员和团队的必要工作。项目经理还可以根据项目的实际情况对项目过程文档进行收集，对所有的文档进行归类 and 整理，给出具体的文档模板并加以指导和要求。

2) 经验教训的收集和形成项目总结会议的讨论稿

在此初始讨论稿中，项目经理有必要列出项目执行过程中的若干主要优点和若干主要缺点，以利于讨论的时候加以重点呈现。

3. 项目总结会

项目总结会需要全体参与项目的成员都参加，并由全体讨论形成文件。项目总结会议所形成的文件一定要通过所有人的确认，任何有违此项原则的文件都不能作为项目总结会议的结果。

项目总结会议还应对项目进行自我评价，有利于后面的项目评估和审计的工作开展。

一般的项目总结会应讨论如下内容。

- (1) 项目绩效：包括项目的完成情况、具体的项目计划完成率、项目目标的完成情况等，作为全体参与项目成员的共同成绩。
- (2) 技术绩效：最终的工作范围与项目初期的工作范围的比较结果是什么，工作范围上有什么变更，项目的相关变更是否合理，处理是否有效，变更是否对项目质量、进度和成本等有重大影响，项目的各项工作是否符合预计的质量标准，是否达到客户满意。